

Consiva.ai Public Knowledge Base

RAG-ready source corpus | Crawled 15 September 2026 | Primary source:

<https://consiva.ai>

Scope and provenance

This document is a cleaned, page-level extraction of the publicly accessible Consiva.ai website. It is intended as a source corpus for retrieval-augmented generation (RAG): each page is kept in a separate section with its source URL and page title so answers can cite the originating page. Navigation, scripts, styles, and decorative markup were removed; substantive headings, paragraphs, lists, labels, pricing text, product claims, legal text, and contact details were retained.

The requested UAT application at <https://uatapp.consiva.ai/> redirects to a login page and was not scraped beyond its publicly visible login shell. No credentials were supplied, so authenticated dashboard data is not included. The public marketing and documentation site at <https://consiva.ai> was used as the authoritative accessible source for this corpus.

Retrieval guidance

Recommended metadata fields: `source_url`, `page_title`, `section_type`, `crawl_date`, and `access_scope=public`. For production ingestion, chunk on the page and subsection headings, preserve the source URL with every chunk, and treat regulatory/legal statements as claims requiring verification against primary law or official regulator guidance. Product pricing, plan limits, dates, and compliance claims may change.

Site inventory

| DPDP Compliance Platform & Consent Management Software India | Consiva.ai |
product/platform | <https://consiva.ai/> | | Privacy Operations Platform for DPDP 2023 | Consiva AI |
product/platform | <https://consiva.ai/platform> | | Consent Management Platform for DPDP 2023 |
Consiva AI | product/platform | <https://consiva.ai/consent-management-platform> | | Cookie
Consent Management Platform India | Consiva AI | product/platform | <https://consiva.ai/cookie-consent-management-platform> | | DPDP and GDPR Consent: Do You Need Both? | Consiva AI |
product/platform | <https://consiva.ai/dpdp-and-gdpr-consent> | | Data Principal Rights
Management under DPDP | Consiva AI | product/platform | <https://consiva.ai/data-principal-rights-management> | | DSAR vs Data Principal Request under DPDP | Consiva AI |
product/platform | <https://consiva.ai/dsar-management-software> | | PII Data Discovery Software
for Databases | Consiva AI | product/platform | <https://consiva.ai/data-discovery-software> | |

Privacy Data Mapping and Data Inventory | Consiva AI | product/platform | <https://consiva.ai/data-mapping-software> | | ROPA Software: Records of Processing Activities | Consiva AI | product/platform | <https://consiva.ai/ropa-software> | | Data Breach Management: CERT-In and DPDP Clocks | Consiva AI | product/platform | <https://consiva.ai/data-breach-management-software> | | Processor and DPA Register for DPDP | Consiva AI | product/platform | <https://consiva.ai/vendor-dpa-register> | | What the DPDP Act Covers — Scope, Application and Key Terms Explained | dpdp reference | <https://consiva.ai/dpdp/dpdp-act-2023> | | DPDP Rules 2025 Explained — What Each Rule Requires and When It Applies | dpdp reference | <https://consiva.ai/dpdp/dpdp-rules-2025> | | DPDP Act Obligations for Data Fiduciaries — Notice, Consent, Security, Breach, Erasure | dpdp reference | <https://consiva.ai/dpdp/data-fiduciary-obligations> | | Data Principal Rights Under the DPDP Act — Access, Correction, Erasure, Nomination | dpdp reference | <https://consiva.ai/dpdp/data-principal-rights-and-duties> | | DPDP Erasure vs Retention — Why Deleting Data on Request Can Breach the Law | dpdp reference | <https://consiva.ai/dpdp/retention-and-erasure> | | DPDP Act Penalties — The Full Schedule, and When It Starts Applying | dpdp reference | <https://consiva.ai/dpdp/penalties-and-enforcement> | | FAQ — DPDP Compliance & Consiva.ai Platform Questions | Consiva.ai | product/platform | <https://consiva.ai/faq> | | DPDP Act for SaaS & IT Companies — The Dual Role Problem, Explained | industry | <https://consiva.ai/industry/saas-it> | | DPDP Act for E-commerce & D2C — The Two Crore Threshold and the Three-Year Clock | industry | <https://consiva.ai/industry/d2c-ecommerce> | | DPDP Act for Banks, NBFCs & Fintech — Where Erasure Meets Mandatory Retention | industry | <https://consiva.ai/industry/bfsi> | | DPDP Act for Hospitals & Healthcare — The Fourth Schedule Carve-Out Explained | industry | <https://consiva.ai/industry/healthcare> | | DPDP Act for EdTech & Schools — When Most of Your Users Are Legally Children | industry | <https://consiva.ai/industry/edtech> | | DPDP Act for Startups — Section 17(3) Is an Enabling Power, Not an Exemption | industry | <https://consiva.ai/industry/startups> | | DPDP Act for Digital Marketing Agencies — Tags, Pixels, Consent and Client Liability | industry | <https://consiva.ai/industry/digital-marketing-agencies> | | DPDP Compliance Blog — Expert Guides for Indian Businesses | Consiva.ai | product/platform | <https://consiva.ai/blog> | | Pricing — DPDP Compliance Platform Plans | Consiva.ai | product/platform | <https://consiva.ai/pricing> | | Contact Consiva.ai — Get a Free DPDP Compliance Assessment | Consiva.ai | product/platform | <https://consiva.ai/contact> | | Data Privacy Platform: Essential Features, Benefits, and Use Cases | Consiva.ai | blog | <https://consiva.ai/blog/data-privacy-platform-features-benefits> | | Privacy Management Platform: How It Helps Organizations Streamline Privacy Operations | Consiva.ai | blog | <https://consiva.ai/blog/privacy-management-platform-streamline-operations> | | DPDP Compliance Tool: Automating Privacy and Data Protection Requirements | Consiva.ai | blog | <https://consiva.ai/blog/dpdp-compliance-tool-automation> | | Privacy Ops: How to Run Data Privacy Work in Real Companies | Consiva.ai | blog | <https://consiva.ai/blog/privacy-ops-guide-modern-businesses> | | DPDP Compliance in India: What Businesses Should Do Next | Consiva.ai | blog | <https://consiva.ai/blog/dpdp-compliance-step-by-step-guide> | | How DPDP Compliance Software Helps Businesses Simplify Data Protection | Consiva.ai | blog |

<https://consiva.ai/blog/how-dpdp-compliance-software-helps-businesses> | | DPDP Privacy Blueprint — Free Guided Assessment | Consiva.ai | product/platform | <https://consiva.ai/privacy-blueprint> | | Privacy Policy — Consiva.ai | legal | <https://consiva.ai/legal/privacy-policy> | | Terms of Service — Consiva.ai | legal | <https://consiva.ai/legal/terms-of-service> | | Cookie Policy — Consiva.ai | legal | <https://consiva.ai/legal/cookie-policy> | | Acceptable Use Policy — Consiva.ai | legal | <https://consiva.ai/legal/acceptable-use-policy> | | Support Policy — Consiva.ai | legal | <https://consiva.ai/legal/support-policy> | | Exercise Your Privacy Rights — Consiva.ai | legal | <https://consiva.ai/legal/privacy-rights-and-grievance> | | Refund & Cancellation Policy — Consiva.ai | legal | <https://consiva.ai/legal/refund-and-cancellation-policy> | | Disclaimers & AI Notice — Consiva.ai | legal | <https://consiva.ai/legal/disclaimers-and-ai-notice> | | Contact Consiva — Sales, Support, Privacy & Security | legal | <https://consiva.ai/legal/contact-us> | | About Consiva.ai — India's DPDP Compliance Platform | Consiva.ai | product/platform | <https://consiva.ai/about> | | Erasure vs Retention Under DPDP: Why Deleting on Request Can Breach the Law | Consiva.ai | blog | <https://consiva.ai/blog/dpdp-erasure-vs-retention> | | Are Your Tags Firing Before Consent? A 10-Minute DevTools Check | Consiva.ai | blog | <https://consiva.ai/blog/tags-firing-before-consent> | | Is the DPDP Act Enforceable Yet? The Commencement Dates, From the Gazette | Consiva.ai | blog | <https://consiva.ai/blog/is-dpdp-enforceable-yet> | | Google Consent Mode v2 and DPDP: What It Does and Doesn't Cover | Consiva.ai | blog | <https://consiva.ai/blog/consent-mode-v2-is-not-consent> | | Rule 8(2) DPDP: The 48-Hour Pre-Erasure Notice, as a System Design Problem | Consiva.ai | blog | <https://consiva.ai/blog/48-hour-pre-erasure-notice> | | DPDP Compliance Software Pricing in India (2026): What It Actually Costs | Consiva.ai | blog | <https://consiva.ai/blog/dpdp-compliance-software-cost-india> | | Consent Manager vs Consent Management Platform Under DPDP: The Difference | Consiva.ai | blog | <https://consiva.ai/blog/consent-manager-vs-cmp> | | OneTrust Alternatives in India for DPDP Compliance (2026) | Consiva.ai | blog | <https://consiva.ai/blog/onetrust-alternatives-india> | | DPDP Data Processing Agreement: What Section 8(2) Actually Requires | Consiva.ai | blog | <https://consiva.ai/blog/dpdp-data-processing-agreement> | | Free DPDP Consent Banner for Indian Websites — What You Get for ₹0 | Consiva.ai | blog | <https://consiva.ai/blog/free-dpdp-consent-banner> | | Breach Response & Regulatory Command Center for Businesses | Consiva.ai | blog | <https://consiva.ai/blog/breach-response-regulatory-command-center-businesses> | | DPDP Act vs GDPR: Key Differences Indian Businesses Must Know | Consiva.ai | blog | <https://consiva.ai/blog/dpdp-vs-gdpr> | | What Is a Consent Management Platform (CMP)? Complete Guide 2025 | Consiva.ai | blog | <https://consiva.ai/blog/what-is-consent-management-platform> | | CERT-In 6-Hour Breach Reporting Rule: Complete Compliance Guide | Consiva.ai | blog | <https://consiva.ai/blog/cert-in-6-hour-breach-reporting> | | How to Implement DPDP-Compliant Cookie Consent on Your Website | Consiva.ai | blog | <https://consiva.ai/blog/dpdp-cookie-consent-implementation> | | Data Principal Rights Under the DPDP Act 2023: Complete Guide | Consiva.ai | blog | <https://consiva.ai/blog/data-principal-rights-dpdp-act> | | DPDP Compliance Checklist for Indian E-Commerce & D2C Businesses | Consiva.ai | blog | <https://consiva.ai/blog/dpdp-compliance-checklist-for-indian-e-commerce-d2c-businesses>

[checklist-ecommerce](#) | | What Is Data Discovery and Why Every DPDP-Regulated Business Needs It | Consiva.ai | blog | <https://consiva.ai/blog/data-discovery-dpdp-compliance> | | DPDP Compliance for SaaS Companies: A Complete Technical Guide | Consiva.ai | blog | <https://consiva.ai/blog/dpdp-compliance-saas-companies> | | How to Automate ROPA Generation for DPDP Compliance | Consiva.ai | blog | <https://consiva.ai/blog/automate-ropa-dpdp-compliance> | | How AI Is Transforming DPDP Compliance Automation for Indian Businesses | Consiva.ai | blog | <https://consiva.ai/blog/ai-powered-dpdp-compliance-automation> |

Extracted page content

1. DPDP Compliance Platform & Consent Management Software India | Consiva.ai

Source URL: <https://consiva.ai/>

DPDP Compliance Platform & Consent Management Software India | Consiva.ai ↑ ISO 9001 Certified · ISO 27001 Certified · NASSCOM Member · DSCI Member · DSCI/AM/2026/089 · DPIIT Recognised · Download White Paper Home Platform Platform Overview See the whole operating model — every module, one dashboard Consent & Notice Consent Management Platform Purpose-specific consent with signed, exportable records Cookie Consent Management Scans every cookie and tracker, including ones you didn't add DPDP and GDPR Consent Already run a GDPR CMP? What changes for DPDP Rights & Grievance Data Principal Rights Management Access, correction, erasure, grievance and nomination DSAR Management Software DSAR vs Data Principal request, explained Discovery, Mapping & Records Data Discovery Software Find personal data at rest, column by column Data Mapping Software Purpose-mapped data inventory from discovery findings ROPA Software A Records of Processing Activities register with source attribution Breach & Incident Data Breach Management CERT-In 6-hour and DPDP Rule 7 clocks, tracked independently Governance Processor & DPA Register Vendor DPA status, risk tiers and expiry alerts DPDP Knowledge DPDP Act 2023 Scope, definitions & key provisions of the law DPDP Rules 2025 Commencement dates & Rule-by-Rule breakdown Data Fiduciary Obligations Notice, consent & lawful processing under §§4–10 Data Principal Rights & Duties Your 4 rights & 5 duties as a data subject Retention & Erasure Rule 8: when to hold data and when to delete it Penalties & Enforcement Full penalty schedule — up to ₹250 Cr per violation FAQ Common questions about DPDP and Consiva Industry SaaS & IT Dual Fiduciary & Processor roles, offshore transfers D2C & E-commerce 2 Cr threshold, purchase consent & 3-year clock BFSI RBI & PMLA retention, defaulter data exemption Healthcare Fourth Schedule carve-out & patient data handling EdTech Rule 10 parental consent & child data protection Startups §17(3) exemptions & lean compliance playbook Digital Marketing Agencies Tag stack liability, Processor vs Fiduciary clarity Blog Pricing Contact Login → Dark  Built for India's DPDP Act 2023 — obligations take effect 13

May 2027 India's Consent Management & DPDP Platform for Global Businesses Start Free — No Credit Card See the Platform Consent, cookies, breach response and Data Principal rights — one platform , built natively for DPDP 2023, not adapted from GDPR.

app.consiva.ai/dashboard Dashboard Consent Logs Rights Requests Breach & Incident Data Discovery Plan Free · Pro · Enterprise Consent overview Last 30 days · acme-corp.in Live — banner active Consents today 4,812 ↑ 12.4% Opt-in rate 68% ↑ 3.1% Cookies scanned 312 6 unclassified Open rights requests 7 2 due in 48h Consent events, by day Recent events Marketing — accepted OK Analytics — withdrawn UPDATED Access request — filed NEW DPDP 2023 CERT-In Directions ISO 27001 Certified India Data Residency ₹250Cr Maximum DPDP penalty per category of violation for a Data Fiduciary DPDP Act 2023 · Section 33 6 hrs CERT-In mandatory breach reporting window — independent of DPDP Board notification CERT-In Directions · April 2022 22 Eighth Schedule languages — consent banners delivered in every official Indian language Indian Constitution · Eighth Schedule 1,000 Cookie consents + 50 form consents free every month — no credit card, no expiry Consiva Free Plan · Forever ISO 9001 Certified NASSCOM Member 🏛️ DSCI Member 🔒 DPIIT Recognised 🇮🇳 DPDP Act 2023 NATIVE CERT-In 2022 6-HR SLA 🇪🇺 GDPR COVERED 🇺🇸 CCPA / CPRA 🇧🇷 LGPD Brazil ☁️ India Data Residency IN-REGION 🗄️ SQL Server · MySQL · PostgreSQL DATA DISCOVERY 🌐 WordPress Plugin ONE-CLICK 🛒 Shopify App ONE-CLICK 📋 ROPA Auto-Generation 👤 DPDP 9 Parental Consent Significant Data Fiduciary Module SDF 🇮🇳 DPDP Act 2023 NATIVE CERT-In 2022 6-HR SLA 🇪🇺 GDPR COVERED 🇺🇸 CCPA / CPRA 🇧🇷 LGPD Brazil ☁️ India Data Residency IN-REGION 🗄️ SQL Server · MySQL · PostgreSQL DATA DISCOVERY 🌐 WordPress Plugin ONE-CLICK 🛒 Shopify App ONE-CLICK 📋 ROPA Auto-Generation 👤 DPDP 9 Parental Consent Significant Data Fiduciary Module SDF The Compliance Imperative The DPDP deadline is real. Most businesses aren't ready. The DPDP Act 2023 is law, with its substantive obligations and penalty regime commencing 13 May 2027. Every digital service processing personal data of Indian residents will be in scope — regardless of where the company is headquartered. ⚠️ Dual Penalty Exposure — DPDP Board + CERT-In hit simultaneously DPDP 2023 imposes up to ₹250 Crore per violation category for inadequate consent mechanisms or failure to fulfil Data Principal rights. CERT-In Directions 2022 impose up to ₹1 Crore for failure to report cybersecurity incidents within 6 hours . A single data breach starts both regulatory clocks simultaneously — yet most consent tools only track one. Consiva tracks both, with independent SLA timers and auto-drafted notification reports for each regulator. Platform Walkthrough Every compliance workflow in one connected dashboard. From cookie consent to CERT-In breach tracking — see exactly how Consiva keeps your organisation compliant across DPDP, GDPR, and CERT-In simultaneously. [consiva.ai/dashboard](https://app.consiva.ai/dashboard) 01 Compliance Dashboard Real-time overview [consiva.ai/banner-builder](https://app.consiva.ai/banner-builder) 02 Visual Banner Builder No-code consent UI [consiva.ai/analytics](https://app.consiva.ai/analytics) 03 Consent Analytics Audit-ready reporting [consiva.ai/consent-logs](https://app.consiva.ai/consent-logs) 04 Consent Logs & Audit Trail Immutable · Exportable [consiva.ai/rights-requests](https://app.consiva.ai/rights-requests) 05 Data Principal Rights DPDP 6, 11–14 compliant [consiva.ai/data-breaches](https://app.consiva.ai/data-breaches) 06 Data Breach Tracker CERT-In 6h · DPDP 72h · Dual-clock [consiva.ai/integrations](https://app.consiva.ai/integrations) 07 Integrations

WordPress · Shopify · Script tag ← → Platform Walkthrough Every DPDP obligation, handled by one platform. DPDP-Native Consent Consent capture designed for India's law — not retrofitted from GDPR. Auto-scans every cookie and tracker on your domain, categorises them by purpose, and presents DPDP-format consent banners in any Eighth Schedule language — deployed via a single script tag. Purpose-specific consent with DPDP 6 format records and immutable timestamp 22 Eighth Schedule languages — Hindi, Tamil, Bengali, Marathi and more Live banner preview with mobile simulation before publishing Consent logs with version, IP, purpose breakdown — regulator-ready consiva.ai/dashboard/banner-builder Data Principal Rights All DPDP Data Principal rights — with email-verified workflows and live SLA timers. DPDP 6, 11–14 gives every Indian user clear rights over their personal data. Consiva automates intake, identity verification, routing, fulfilment, and the immutable audit trail — with escalation before SLA breach. Consent Withdrawal · Access to Information · Correction & Erasure · Grievance · Nomination 7-day and 30-day SLA countdown with auto-escalation to DPO Email-verified identity confirmation before any data action Full case audit trail — regulator-exportable PDF consiva.ai/dashboard/rights CERT-In Breach Tracker The only Indian consent platform with an independent CERT-In 6-hour SLA tracker. A data breach triggers two separate regulatory clocks simultaneously. Consiva tracks both independently — CERT-In's 6-hour window and DPDP Board's notification window — with auto-drafted reports for each regulator. Separate 6-hr CERT-In countdown, independent of the DPDP Board window 180-day incident log retention per CERT-In Directions 3(iv) Auto-drafted CERT-In report, pre-filled for cert-in.org.in submission Escalation alerts before either regulatory deadline lapses consiva.ai/dashboard/breaches Data Discovery Find personal data hiding in your databases — automatically. Connect your database in one click. Consiva scans every table, flags personal data at rest, and maps it to your DPDP processing purposes — powering your ROPA automatically. Microsoft SQL Server ENTERPRISE · EXPRESS · AZURE SQL BUILT-IN Connect via host, port, and credentials. Passwords are encrypted at rest and write-only — never exposed in any API response. Scans all tables for PII column patterns. Auto-detects email, phone, name, Aadhaar patterns Maps columns to DPDP processing purposes Generates ROPA entries automatically PostgreSQL V12+ · SUPABASE · AWS RDS BUILT-IN Full schema introspection across all schemas and tables. Works with managed PostgreSQL on Supabase, AWS RDS, and self-hosted. Encrypted credential storage. Scans all schemas, tables, and views Regex + pattern classification of PII columns Repeat scans with incremental diff report MySQL / MariaDB MYSQL 5.7+ · MARIADB · AURORA BUILT-IN Connects to any MySQL-compatible database. Scans non-system tables only — safe for production environments. Supports SSL/TLS connections. Non-system schema scan — zero production risk Supports SSL/TLS encrypted connections Compatible with WooCommerce, Magento DBs One-Click CMS & E-commerce Integrations WordPress OFFICIAL PLUGIN Install the Consiva Consent Banner plugin from WP Plugins. Paste your Script Key from the Consiva dashboard. Done — banner live on every page, zero code required. Settings → Consiva Consent Banner → Paste Script Key → Save Shopify ONE-CLICK Install from the Shopify App Store in one click. Auto-injects your consent banner on every storefront

page, syncs with Shopify's Customer Privacy API, and captures marketing opt-in at checkout.

App Store → Install Consiva Consent → Enter Script Key → Save Compliance Scope

If you process Indian users' data, DPDP applies to you. E-Commerce & D2C Checkout data, order history, returns, loyalty programmes — DPDP regulates every bit of it. Healthcare & Wellness Patient records and health app data are sensitive personal data with stricter DPDP obligations. BFSI & Fintech KYC, transaction histories, and credit data — under both DPDP and RBI data governance frameworks. SaaS & Mobile Apps Any SaaS processing Indian user data — regardless of server location — is in scope. EdTech & Online Learning Student data and minors' data invoke DPDP 9 parental consent — one of its strictest provisions. Global Enterprises Overseas companies with Indian customer data must comply. DPDP follows the data, not the domicile. Platform Capabilities Everything DPDP requires. Nothing compliance teams don't. Automatic Cookie & Tracker Scanning Continuous scanner discovers every cookie, pixel, and third-party script on your domains — including those added by CMS plugins or tag managers without your knowledge. Auto-categorised and mapped to consent purposes on every scan cycle. Necessary Analytics Marketing Preferences Third-party ROPA Auto-generation Records of Processing Activities built automatically from scan results, consent logs, and Data Discovery findings. Updated on every scan cycle — always current for regulator review. Parental Consent (DPDP 9) DPDP mandates verifiable parental consent before processing children's data. Consiva provides age-gate logic, verification workflow, and a complete audit trail per minor user. Multi-Framework Geolocation Serve GDPR banners in the EU, CCPA opt-outs in California, and DPDP banners in India — auto-switched by visitor location. All from one script tag, one dashboard. India Data Residency All consent logs, rights request records, and breach reports stored exclusively in India — meeting DPDP data localisation provisions on every plan. Consent Analytics Opt-in rates by banner variant, category, domain, and traffic source. AB test banner text to optimise consent rates without compromising compliance. Immutable Audit Logs Every consent event, rights action, and breach record written to an append-only log. Tamper-evident, exportable, and ready for regulator review at any time. SDF Module Significant Data Fiduciary obligations — DPO workflow management, DPIA templates, annual audit readiness, and algorithmic accountability dashboards. Enterprise plan. Vendor Register & DPA Tracking Maintain a live register of all data processors, their DPA status, risk tiers, and sub-processor chains. Get alerted when a DPA expires or a vendor's risk profile changes. SCC templates included. Webhooks & Real-Time Events Push consent events, rights-request updates, and breach alerts to your own systems in real time via HMAC-SHA256 signed webhooks. REST API available for custom integrations on Pro and Enterprise plans. Quick Start Live in 10 minutes. Compliant for years.

01 Register & Verify Your Domain Create your free account at app.consiva.ai — no credit card required. Add your domain and click Verify. Consiva confirms ownership and starts the first cookie scan immediately.  1,000 cookie consents + 50 form consents free — every month, forever

02 Review Cookies & Set Purposes The scanner returns every cookie, pixel, and tracker with suggested DPDP purpose categories pre-filled. Review, adjust, and add custom purposes matching your processing activities.

03 Configure Banner &

Language Choose your banner layout, accent colour, and language. Select from 22 Eighth Schedule languages. Preview on mobile and desktop before publishing. 04 Deploy — One Script Tag Copy a single Step 2: Take your analytics code out of the HTML. Then add those scripts in the Consiva dashboard as Managed Scripts. The SDK will place them in after the user agrees. Step 3: Put a link for saved choices in your footer like this: [Cookie Settings](#) Step 4 (SPAs): If you use React, Vue, or Angular, use the Consiva browser API: `import { ConsivaClient } from '@consiva/sdk'; const client = new ConsivaClient({ siteId: 'YOUR_SITE_ID' }); client.onConsentUpdate((consent) => { if (consent.analytics) initGoogleAnalytics(); if (consent.marketing) initMetaPixel(); });` Step 5: Enable Google Consent Mode v2 in your Consiva dashboard if running Google Ads. Consiva automatically fires `gtag('consent', 'update', ...)` signals when consent changes. How to Test Your Consent Implementation Use this 10-point checklist to verify genuine compliance — not just cosmetic presence: Open site in private/incognito window — consent banner must appear immediately Click “Reject All” — verify zero analytics/marketing requests in the Network tab Click “Accept All” — verify GA4 pageview fires within seconds Open “Manage Preferences” — all categories must default to OFF Accept Analytics only — analytics fires; marketing does not Reload page — banner must NOT reappear; consent must persist Click footer “Cookie Settings” link — preferences panel opens Withdraw Analytics, click Save — analytics must not fire on next page load Test on mobile — banner readable; buttons must be at least 44×44px touch targets Test in Hindi/regional language if serving those users — notice must be readable Consent Record Keeping Store the following fields for every consent event. Minimum retention: 3 years . Field Purpose Consent Event ID Unique identifier for audit traceability Consent Version Hash of the notice text shown — proves the notice was current Timestamp (UTC) Proves consent preceded processing Categories Accepted Granular proof of valid consent scope User Identifier (hashed) Links consent to data subject without storing raw PII User Agent Technical context for audit Hashed IP Fraud and bot detection Withdrawal Record Timestamp & categories withdrawn (if applicable) Common Mistakes to Avoid The five most common ways a consent banner fails DPDP — and what compliant looks like instead. ✗ Soft Opt-In (“By continuing to browse...”) DPDP Section 6 requires a clear affirmative action. Passive browsing does not constitute consent. ✗ Pre-Ticked Analytics or Marketing Categories All non-essential categories must default to OFF. Pre-ticking any category makes consent non-free and non-unambiguous — both DPDP violations. ✗ Dark Pattern: Making “Reject All” Harder Than “Accept All” Equal visual prominence is required. A large green Accept button with a tiny grey Reject link invalidates the “free” consent standard under DPDP. ✗ Banner Without Technical Enforcement Showing a banner while allowing analytics to load regardless of user choice. Script blocking (not just disclosure) is mandatory for DPDP compliance. ✗ Blocking Service Access to Users Who Decline DPDP Section 6(6) prohibits making non-essential consent a condition of service. A “please accept cookies to continue” gate is explicitly non-compliant. Frequently Asked Questions Do I need cookie consent if my website only serves Indian users? + Yes, under the DPDP Act 2023 you do — it applies to all digital personal data processed within India. If your site grabs personal info from Indian

visitors via analytics, advertising tags, or cookie preferences you have to get the right kind of consent before processing starts. Where your website is hosted just isn't the deciding factor, what matters is where the person is located who the data is being done on. Can I use Google Consent Mode instead of a full CMP? + Google Consent Mode v2 is a signal protocol — it communicates consent status to Google's systems. It is not a CMP. It does not present a banner, collect consent, store records, or handle withdrawal. You need a CMP like Consiva.ai to collect consent and send signals to Google Consent Mode. Both Consiva support and custom HTML/JS implementation can work hand in hand, no need to choose one over the other. What languages must my cookie banner support? + DPDP requires notices in "clear and plain language." For broad B2C platforms: at minimum Hindi and English. For regional e-commerce or service platforms you'll want to make sure you have the primary language of your target audience (Tamil, Telugu, Bengali, Marathi, and the rest). Consiva supports all 22 scheduled Indian languages with automatic browser detection. How often do I need to re-collect cookie consent? + Re-collect when: (1) your cookie list changes materially — new cookies added, new purposes declared; (2) your privacy policy changes in ways affecting processing; (3) stored consent has expired (typically 12 months). Consiva's consent versioning automatically identifies outdated consents and triggers re-collection. What is a dark pattern in cookie consent and is it illegal under DPDP? + A dark pattern manipulates users into accepting non-essential cookies — e.g., a large green Accept button with a tiny grey Reject link, or auto-selecting all categories. These violate DPDP Act 2023 Section 6, which requires consent to be "free" — not obtained through manipulation. The Data Protection Board of India can investigate and penalise dark patterns in consent UX. Go Live with DPDP-Compliant Consent Today Consiva handles the entire consent lifecycle: banner, enforcement, audit trail, 22 Indian languages, and withdrawal — for WordPress, Shopify, and custom sites. Start Free — No Credit Card → View Pricing Related Articles Continue learning about DPDP compliance Consent Management What Is a Consent Management Platform? A Complete Guide for Indian Businesses Read article → DPDP Compliance DPDP Act vs GDPR: Key Differences Every Indian Business Must Know Read article → DPDP Compliance Data Principal Rights Under India's DPDP Act 2023: A Complete Business Guide Read article → Get DPDP Implementation Updates New guides, compliance checklists, and rule notifications delivered to your inbox. No spam. I agree to receive DPDP compliance updates and consent to Consiva processing my email for this purpose. Privacy Policy . Subscribe Table of Contents DPDP on Cookie Consent Required Banner Elements Cookie Categories Withdrawal Requirement Multi-Language Support WordPress Shopify Custom Sites Testing Record Keeping Common Mistakes FAQ India's DPDP compliance platform and consent management software — built natively for DPDP 2023, CERT-In, and global privacy frameworks. DPDP 2023 CERT-In GDPR Made in India  ISO 9001 Certified ISO 27001 Certified NASSCOM Member DSCI · DSCI/AM/2026/089 DPIIT Recognised Privacy contact (Rule 9): Saurabh K, Privacy Officer & Grievance Officer saurabhk@swaransoft.com DPDP Knowledge DPDP Act 2023 DPDP Rules 2025 Data Fiduciary Obligations Data Principal Rights & Duties Retention & Erasure Penalties & Enforcement Compliance Blog Privacy

Blueprint Industries SaaS & IT D2C & E-commerce BFSI Healthcare EdTech Startups Digital Marketing Agencies Trust & Legal Privacy Policy Terms of Service Cookie Policy Acceptable Use Policy Support Policy Privacy Rights & Grievance Refund & Cancellation Disclaimers & AI Notice Contact & Routing Company About Us Pricing Blog FAQ Contact Sitemap Login → Ask AI About Consiva Get an instant AI-generated overview Open your favorite AI assistant with a ready-made prompt about Consiva ChatGPT Perplexity Claude Google AI Grok © Consiva.ai · A product of Swaran Soft Support Solutions Private Limited CIN: U72200DL2005PTC136405 · GSTIN: 06AAJCS7515G1Z9 Tower A, Unit No. 2, 2nd Floor, The Cityscape, Sector-66, Golf Course Extension Road, Gurugram, Haryana – 122102, India support@consiva.ai · +91 9220313650 · ISO 9001:2015 & ISO/IEC 27001:2022 certified management systems within the scope of providing software development services.

62. Data Principal Rights Under the DPDP Act 2023: Complete Guide | Consiva.ai

Source URL: <https://consiva.ai/blog/data-principal-rights-dpdp-act>

Correction

Correct inaccurate or misleading personal data Completion

Have incomplete personal data completed Update

Update personal data that is out of date Erasure

Have personal data erased when the purpose for which it was collected is no longer being served The correction right is relatively straightforward to implement: provide a mechanism for data principals to submit corrections, verify their identity, update the data across all systems (not just the primary CRM — also in email lists, data warehouses, and anywhere the data has been replicated), and notify any third parties who have received the incorrect data. The erasure right is more complex. According to DPDP Act 2023, Section 8(7), a Data Fiduciary shall not retain personal data beyond the period necessary to satisfy the purpose for which it was collected. The erasure right essentially operationalises this retention principle: when a data principal requests erasure and you have no remaining purpose or legal obligation for their data, you must erase it. Comprehensive erasure is a must — just hitting ‘delete’ on a record in your CRM system isn’t enough, you need to make sure that all the details are wiped from all systems & backups too, within a reasonable amount of time. That means getting rid of the data from things like analytics databases, email marketing platforms & even sending a message to third-party processors to delete the data too. And it’s not just them you need to inform, they have to be audited to ensure they are erasing the data properly. Right to Grievance Redressal (Section 13) DPDP Act 2023 — Section 13 Two-Tier Grievance Mechanism Section 13 establishes a two-tier grievance redressal system: Tier 1 Data Principal raises a grievance directly with the Data Fiduciary through its designated grievance mechanism Tier 2

If the grievance is not resolved within the period prescribed by the Rules, the Data Principal may approach the Data Protection Board of India. Every Data Fiduciary must publish a grievance redressal mechanism — a designated contact point (email address, web form, or dedicated portal) where data principals can file complaints about how their data has been handled. The contact details of the grievance mechanism must be provided in your Privacy Notice as required by Section 5. The Grievance Officer, or the Data Fiduciary's nominated contact, has to reply quickly. The issue should be settled within the time limit set out in the Rules. If the Data Principal is still not satisfied after that, the matter can be taken to the Data Protection Board of India. The Board can look into it and order penalties if it finds that rules were not followed. For Significant Data Fiduciaries, as listed under Section 10, the duties are more strict. They must name a Data Protection Officer who is based in India. This DPO acts as the step before the case reaches the Data Protection Board of India.

Right to Nominate (Section 14) DPDP Act 2023 — Section 14

Nomination for Death or Incapacity Section 14 grants every Data Principal the right to nominate another individual who shall, in the event of the Data Principal's death or incapacity, exercise the rights of the Data Principal in accordance with the provisions of the Act. This right is unique to India's DPDP Act — there is no equivalent provision in GDPR or any other major data protection framework. The nomination mechanism must be made available by Data Fiduciaries, though the specific process and registration format will be prescribed in the Rules. In day to day work, an organization has to do four things. First, it needs a way to record a nominee. This can be a form. The form should let people add the nominee's name, link to the person, and contact details. Second, it must keep the nomination data safe. The record should be tied to the account of the data principal. Third, it must check the nominee's identity. It must also confirm the data principal is dead or unable to act, before the nominee uses rights on that person's behalf. Fourth, it must treat requests from a verified nominee with the same care it gives to requests made by the data principal directly.

Right to Withdraw Consent (Section 6(4)) According to DPDP Act 2023, Section 6(4): "A Data Principal shall have the right to withdraw consent at any time, with the ease of the same manner in which consent was given, and upon such withdrawal, the Data Fiduciary shall, within a reasonable period, cease and cause its Data Processors to cease processing the personal data of the Data Principal." From this rule, three duties follow. One, the act of withdrawal should be as simple as giving consent. Two, once withdrawal happens, the data fiduciary must stop processing in a "reasonable period" — for tech like cookies and tracking, this should mean stopping right away. Three, the data fiduciary must also make sure its data processors stop, so you have to inform your third parties, like Google Analytics, Meta, and your email tool. The right to withdraw consent for cookie tracking is handled by your consent management platform. The right to withdraw consent for ongoing data processing activities (e.g., withdrawing consent to a personalisation programme you enrolled in) requires a separate DSR (Data Subject Request) workflow with SLA tracking. See our guide on cookie consent implementation for

the technical side of consent withdrawal. Automate Data Principal Rights Fulfilment

Consiva's DSR module handles all five rights — access, correction, erasure, grievance, and nomination — with SLA timers, identity verification, and immutable evidence trails.

Start Free on Consiva.ai — No Credit Card → SLA Timelines for Each Right

The specific response timelines will be prescribed in the DPDP Rules. Based on the draft Rules circulated for public consultation and international best practice, the following working timelines should be used for operational planning:

Right Working SLA Notes

Access (Section 11) 30 days From receipt of valid, verified request. Complex requests may require extension.

Correction (Section 12) 30 days Must propagate correction to all systems and notify downstream processors.

Erasure (Section 12) 30 days For front-end systems; backup erasure within 90 days. Legal holds may extend.

Grievance Redressal (Section 13) 30 days Acknowledge within 24–48 hours; resolve within 30 days. Board escalation if unresolved.

Nomination Registration (Section 14) 7 days Confirm nomination registration to the Data Principal.

Consent Withdrawal (Section 6(4)) Immediate

Cookie/tracking consent: real-time. Other processing: within reasonable period.

These timelines are working estimates based on draft Rules. When final Rules are notified, update your SLAs accordingly.

Consiva's DSR module automatically starts SLA timers when a request is received and sends escalation alerts as deadlines approach.

Identity Verification Before Fulfilling Rights

Before fulfilling any Data Principal rights request, you must verify that the requester is actually the Data Principal (or their authorised nominee). Without verification, you risk:

- Disclosing personal data to an unauthorised third party (a separate DPDP violation)
- Erasing data based on a fraudulent request, harming the legitimate Data Principal
- Correcting data incorrectly based on an impersonation attempt

Practical identity verification approaches:

- Authenticated portal

Require the requester to log in to their account before submitting a rights request. This links the request to a verified identity.

Email verification

so for people who have emailed in, you need to send a verification link to the actual email address linked to the account, their on-file address.

Government ID for high-risk requests

so when you get a request for erasure or access to sensitive stuff then you need a link to a real government ID (Aadhaar, PAN, Passport) — but make sure you don't ask for more ID than you need.

Callback verification

For phone-submitted requests, call the registered phone number for verbal confirmation.

Do not over-verify. Requiring excessive proof of identity for simple correction requests can itself be a barrier that violates the spirit of the rights.

Match verification level to the sensitivity of the requested action.

Erasure Requests and Legal Retention Obligations

A common operational challenge arises when a Data Principal requests erasure of their data, but the organisation has a legal obligation to retain that data.

Common examples in India:

- Income Tax Act records

Financial transaction data may need to be retained for 6–8 years

PMLA (Prevention of Money Laundering Act)

KYC and transaction records for regulated entities — 5 years Companies Act 2013

Certain company records indefinitely; others for 8 years GST records

6 years from the due date of the relevant annual return Labour law records

Employment records varying by state and type When an erasure request conflicts with a legal retention obligation: Acknowledge the request promptly Explain the specific legal basis for retention (cite the statute and section) Commit to erasing the data as soon as the legal retention period expires During the retention period, restrict processing to the purpose of the legal obligation only — do not use retained data for marketing, analytics, or any other purpose Document your decision with the legal basis cited — this is your evidence if the Data Protection Board investigates Building a DSR Workflow A Data Subject Request (DSR) workflow is the operational process your organisation uses to receive, verify, process, and respond to Data Principal rights requests. A compliant DSR workflow has seven components: Intake mechanism — the public-facing channel people use to submit rights requests: web form, email address (e.g., privacy@yourcompany.com), or maybe an in-app self-service portal. Automated acknowledgement — which has to be sent within 24–48 hours, and it needs to include a reference number and some sort of idea of when you'll get back to them with an answer. SLA timer — Start the 30-day (or applicable) SLA clock from the moment a verified, complete request is received. Escalation alerts at 15 days, 25 days, and 29 days remaining. Identity verification — Verify the requester's identity using methods appropriate to the risk level of the requested action. Do not start the SLA timer until identity is verified. Data inventory lookup — you need to trawl through all your systems, CRM, databases, email platforms etc to find any and all personal details you've got stored about the Data Principal. Fulfilment and downstream notification — follow through with the request (provide a summary, correct the data, delete it, etc) and send a notification to all the Data Processors who have copies of that info to tell them to do the same. Evidence trail — Record every step: intake timestamp, verification method, SLA clock start, data lookup results, fulfilment actions, downstream notifications, and response sent. This evidence trail is your defence in a Data Protection Board investigation. How Consiva Automates Rights Fulfilment End-to-End Consiva's Data Principal Rights module provides complete DSR automation for the DPDP Act 2023 rights framework: Self-Service Rights Portal

A branded portal where your data principals can submit access, correction, erasure, grievance, and nomination requests. Login-based identity verification is automatic.

Automatic SLA Timers

each type of request gets its own timer, and if things don't get moved along quick enough, you can set up notifications to your privacy team at configurable intervals (15 days, 25 days, and the day before the deadline for a 30-day request). Data Inventory Integration Consiva hooks up to your CRM, database and cloud storage to find personal data scattered across all your systems, and then it auto-generates the response so you don't have to lift a finger. Third-Party Processor Notifications

when you've done the request, be it an erasure or a correction, Consiva automatically sends out notification emails to your configured Data Processors (Google Analytics, Mailchimp, Salesforce, etc) with the info they need to get the same job done. Immutable Evidence Trail

every single DSR action is logged with a timestamp, a user ID and what they did, and then you can export that lot in a format the Data Protection Board will love. Nomination Registration

a dedicated nomination form lets Data Principals name someone to act for them, connecting the nominee to the account, after which the portal carries out the identity checks. Consiva's DSR module is available on all plans — view pricing . For enterprise implementations with complex data inventory integrations, contact our compliance team . Ready to start? Try it free — no credit card required. Frequently Asked Questions What on earth is a Data Principal under the DPDP Act 2023? + To be honest a Data Principal is just the person whose personal data you're dealing with — defined as such under Section 2(j) of the DPDP Act 2023. In simpler terms — it's your users, customers, employees, or anyone else whose data you're looking after. And if that Data Principal is a kid (under 18), then someone's gotta exercise those rights on their behalf — usually a parent or some other sort of lawful guardian. How quickly must a Data Fiduciary respond to a rights request? + Specific timelines will be prescribed in DPDP Rules (not yet finalised as of mid-2025). Based on draft Rules and international practice, 30 days is the working benchmark for standard requests. The "without undue delay" principle applies throughout. Consent withdrawal for cookie tracking must take effect immediately (technically). Organisations should build workflows capable of responding within 30 days as a conservative default until final Rules are published. Can a Data Fiduciary charge a fee for handling rights requests? + The DPDP Act does not explicitly permit fees for responding to rights requests. The default position is that responding to Data Principal rights requests is a compliance obligation that cannot be monetised. This contrasts with GDPR, which allows "reasonable fees" for manifestly unfounded or excessive requests. Under DPDP, demanding fees for rights responses could itself constitute a violation of the Data Principal's rights. When an erasure request hits a snag with a legal retention duty + When someone asks for erasure but there's a law that says you have to keep the data (like the Income Tax Act or the Companies Act), the Data Fiduciary gets to hold onto it for as long as the law says they have to. What happens then: (1) they have to let the person know they've got their request; (2) they explain why the data has to stay around by pointing to the specific law that says so, along with the actual name of the law; (3) they promise to get around to erasing the data as soon as the law says they can; (4) for the time being, the Data Fiduciary is only allowed to look at the data so they can stick to what the law says they have to do — no sneaking in any marketing or analytics work on it; and (5) to keep themselves covered, they have to write down why they're keeping the data, including the law that says they have to — that's their evidence record. What is the Right to Nominate

and does GDPR have an equivalent? + Section 14 of the DPDP Act 2023 grants every Data Principal the right to nominate another individual to exercise their data rights in the event of death or incapacity. This nomination is registered with the Data Fiduciary and activated when the Data Principal's death or incapacity is verified. GDPR has no equivalent right — this is unique to India's DPDP Act. Data Fiduciaries must build nomination registration and succession mechanisms into their DSR workflows. Automate Data Principal Rights — Start Free Consiva's DSR module covers all five DPDP rights with SLA timers, identity verification, and immutable evidence trails. No credit card to start. Start Free — No Credit Card → View Pricing Related Articles Continue learning about DPDP compliance DPDP Compliance DPDP Act vs GDPR: Key Differences Every Indian Business Must Know Read article → CERT-In Compliance CERT-In 6-Hour Breach Reporting Rule: Everything You Need to Know Read article → Consent Management What Is a Consent Management Platform? A Complete Guide for Indian Businesses Read article → Stay Ahead of DPDP Compliance New guides, rule updates, and compliance templates delivered to your inbox. No spam — unsubscribe anytime. I agree to receive DPDP compliance updates and consent to Consiva processing my email for this purpose. Privacy Policy . Subscribe Table of Contents Who Is a Data Principal? Right to Access (Section 11) Correction & Erasure (Section 12) Grievance Redressal (Section 13) Right to Nominate (Section 14) Withdraw Consent (Section 6(4)) SLA Timelines Identity Verification Erasure vs Legal Retention DSR Workflow How Consiva Automates FAQ India's DPDP compliance platform and consent management software — built natively for DPDP 2023, CERT-In, and global privacy frameworks. DPDP 2023 CERT-In GDPR Made in India  ISO 9001 Certified ISO 27001 Certified NASSCOM Member DSCI · DSCI/AM/2026/089 DPIIT Recognised Privacy contact (Rule 9): Saurabh K, Privacy Officer & Grievance Officer saurabhk@swaransoft.com DPDP Knowledge DPDP Act 2023 DPDP Rules 2025 Data Fiduciary Obligations Data Principal Rights & Duties Retention & Erasure Penalties & Enforcement Compliance Blog Privacy Blueprint Industries SaaS & IT D2C & E-commerce BFSI Healthcare EdTech Startups Digital Marketing Agencies Trust & Legal Privacy Policy Terms of Service Cookie Policy Acceptable Use Policy Support Policy Privacy Rights & Grievance Refund & Cancellation Disclaimers & AI Notice Contact & Routing Company About Us Pricing Blog FAQ Contact Sitemap Login → Ask AI About Consiva Get an instant AI-generated overview Open your favorite AI assistant with a ready-made prompt about Consiva ChatGPT Perplexity Claude Google AI Grok © Consiva.ai · A product of Swaran Soft Support Solutions Private Limited CIN: U72200DL2005PTC136405 · GSTIN: 06AAJCS7515G1Z9 Tower A, Unit No. 2, 2nd Floor, The Cityscape, Sector-66, Golf Course Extension Road, Gurugram, Haryana – 122102, India support@consiva.ai · +91 9220313650 · ISO 9001:2015 & ISO/IEC 27001:2022 certified management systems within the scope of providing software development services.

63. DPDP Compliance Checklist for Indian E-Commerce & D2C Businesses | Consiva.ai

Source URL: <https://consiva.ai/blog/dpdp-compliance-checklist-ecommerce>

DPDP Compliance Checklist for Indian E-Commerce & D2C Businesses | Consiva.ai ↑ ISO 9001 Certified · ISO 27001 Certified · NASSCOM Member · DSCI Member · DSCI/AM/2026/089 · DPIIT Recognised · Download White Paper Home Platform Platform Overview See the whole operating model — every module, one dashboard Consent & Notice Consent Management Platform Purpose-specific consent with signed, exportable records Cookie Consent Management Scans every cookie and tracker, including ones you didn't add DPDP and GDPR Consent Already run a GDPR CMP? What changes for DPDP Rights & Grievance Data Principal Rights Management Access, correction, erasure, grievance and nomination DSAR Management Software DSAR vs Data Principal request, explained Discovery, Mapping & Records Data Discovery Software Find personal data at rest, column by column Data Mapping Software Purpose-mapped data inventory from discovery findings ROPA Software A Records of Processing Activities register with source attribution Breach & Incident Data Breach Management CERT-In 6-hour and DPDP Rule 7 clocks, tracked independently Governance Processor & DPA Register Vendor DPA status, risk tiers and expiry alerts DPDP Knowledge DPDP Act 2023 Scope, definitions & key provisions of the law DPDP Rules 2025 Commencement dates & Rule-by-Rule breakdown Data Fiduciary Obligations Notice, consent & lawful processing under §§4–10 Data Principal Rights & Duties Your 4 rights & 5 duties as a data subject Retention & Erasure Rule 8: when to hold data and when to delete it Penalties & Enforcement Full penalty schedule — up to ₹250 Cr per violation FAQ Common questions about DPDP and Consiva Industry SaaS & IT Dual Fiduciary & Processor roles, offshore transfers D2C & E-commerce 2 Cr threshold, purchase consent & 3-year clock BFSI RBI & PMLA retention, defaulter data exemption Healthcare Fourth Schedule carve-out & patient data handling EdTech Rule 10 parental consent & child data protection Startups §17(3) exemptions & lean compliance playbook Digital Marketing Agencies Tag stack liability, Processor vs Fiduciary clarity Blog Pricing Contact Login → Dark Home > Blog > DPDP Compliance Checklist for Indian E-Commerce & D2C DPDP Compliance 12 min read DPDP Compliance Checklist for Indian E-Commerce & D2C Businesses The Digital Personal Data Protection Act 2023 creates concrete obligations for every brand that collects customer data online. This actionable 12-point checklist tells you exactly what to build, review, and automate — so you reach compliance without paralysis. CE Consiva Editorial Team 1 June 2026 ~2,200 words Table of Contents Why E-commerce Is High-Risk

1. Cookie Consent Banner
2. Privacy Notice / Policy
3. DSR Workflow

4. Breach Notification Readiness
5. Vendor / Processor DPAs
6. Data Minimisation
7. Retention & Deletion Schedule
8. Children's Data Check
9. Employee Training
10. Breach Response Plan
11. ROPA
12. Annual Privacy Audit FAQ Related Posts Why Indian E-Commerce & D2C Brands Face Elevated DPDP Risk E-commerce and D2C companies in India operate right in the middle of many data privacy threats that the Digital Personal Data Protection Act, 2023 aims to cover. During one checkout, a buyer may share their name, phone number, email, shipping address, payment details, and browsing related choices. That data then fans out to payment gateways, logistics partners, remarketing platforms, CRM tools, and customer-support helpdesks — often without the customer having any clear picture of where their information goes. The DPDP Act changes this. It defines anyone who determines the purpose and means of processing personal data as a Data Fiduciary — placing the legal responsibility squarely on the brand, not the technology vendor. The law allows penalties up to ₹250 crore for each breach event. The Data Protection Board of India can also audit, probe, and impose sanctions. For newer brands that are growing fast, with large customer databases and small legal teams, this threat can be a deal breaker unless they plan ahead. For context, the penalty exposure across key violation categories: Violation DPDP Act Section Maximum Penalty Failure to implement reasonable security safeguards Section 8(5) Up to ₹250 Crore Failure to notify DPB of personal data breach Section 8(6) Up to ₹200 Crore Non-fulfilment of obligations for children's data Section 9 Up to ₹200 Crore Non-fulfilment of Significant Data Fiduciary obligations Section 10 Up to ₹150 Crore Failure to honour Data Principal rights requests Sections 12–14 Up to ₹50 Crore Breach of any other DPDP Act obligation Schedule, Item 7 Up to ₹50 Crore This checklist gives you a concrete, actionable framework — 12 items that cover the full lifecycle from data collection through deletion, plus the governance structures that prove compliance. Each item maps to specific DPDP Act sections and tells you exactly what to build. Checklist Item 01 Cookie Consent Banner (DPDP Section 6) What It Means Under Section 6 of the DPDP Act, consent has to be free, specific, informed, unconditional, and clear. If consent is coming from pre-ticked boxes, tied choices or hidden opt-out, it does not match the rule. For an e-commerce site that deploys analytics cookies, advertising pixels (Meta Pixel, Google Ads), and third-party chat widgets, every category of cookie that processes personal data needs a distinct consent choice — and that choice must be granular. Why It Matters Advertising-dependent e-commerce brands

are particularly exposed. Running Meta Pixel or Google Enhanced Conversions without proper consent constitutes processing personal data without a lawful basis. Beyond the regulatory penalty, ad platforms themselves are increasingly requiring proof of consent for signal verification. Non-compliance risks both regulatory sanction and platform restrictions on ad delivery — a double blow to performance-marketing-driven D2C growth models.

How to Implement Audit every script on your site using a tag scanner — identify which ones collect or share personal data before any user interaction. Split cookie choices into these groups, keeping each one as its own option: Strictly Necessary, Functional, Analytics, and Advertising and Marketing. Use a consent management platform like Consiva.ai . Show a banner on the first visit, before any non-essential scripts start running. Ensure your CMP blocks non-consented scripts at load time — not just via a visual banner that fires scripts anyway in the background. Record consent timestamps, user choices, and the version of your privacy notice shown at the time of consent. This audit log is your proof of lawful basis if questioned. Provide an equally prominent opt-out mechanism in your site footer and account settings — making it as easy to withdraw consent as it was to give it, as required by Section 6(4). Re-show the consent banner to returning users whenever your privacy notice version changes materially.

Checklist Item 02 Privacy Notice / Policy (DPDP Section 5) What It Means Section 5 mandates that the Data Fiduciary give a notice to the Data Principal — before or at the time of collecting personal data — that is clear, plain-language, and contains: (a) the personal data being collected, (b) the purpose of processing, © how to exercise rights under Sections 12 to 14, and (d) how to file a complaint with the Data Protection Board. Your existing generic privacy policy almost certainly does not meet this standard. **Why It Matters** A non-compliant privacy notice invalidates the consent obtained under it. This is not merely a documentation problem — it means every marketing email sent, every retargeted ad served, and every customer record retained after that notice was used may lack a valid lawful basis. Courts and regulators look at the notice at the moment of consent, not the one on your site today.

How to Implement Rewrite the privacy policy using plain language. Do not use heavy legal wording. Use clear section titles. Add bullet points. Add a table of contents so readers can jump to what they want quickly. Put the notices in parts. First, show a short notice at the moment you collect the data. For instance, during checkout, tell the person you need the shipping address to send the order. Also say you need a phone number so you can handle delivery questions. Second, place the full privacy policy nearby so people can read the complete details if they want to. List out every single third-party processor you send data to — logistics providers, payment gateways, analytics platforms, remarketing tools, and customer support desks. Make sure you've got a dedicated "Your Rights" section with super clear instructions on how to submit Data Subject Requests, including a link to your DSR intake form. Update the policy over time and keep older versions too — regulators may ask to see what notice was shown when you first collected the data.

Checklist Item 03 Data Subject Request (DSR) Workflow (DPDP Sections 12, 13, 14) What It Means Sections 12, 13, and 14 of the DPDP Act give data

principals the right to ask for a summary of their personal data and what's happening with it (12), fix any mistakes in their info (13), and wipe their data and withdraw consent (14). The Act expects that these rights should be super easy to exercise — most places say 30 days is a reasonable time to get back to someone with the answer. Rules under the DPDP Act will probably formalize similar timelines. Why It Matters E-commerce shops get DSRs all the time — customers asking to delete their account, update their address, or just know what data you've got on file. Without a clear plan in place, these requests get lost in the support queues or get handled in a million different ways — that creates compliance headaches and a seriously bad customer experience. And let's be honest, if you don't even know where to start looking for that customer's data in your CRM, order management system, loyalty program, and email platform then you can't even fulfill a deletion request. How to Implement Build or procure a dedicated DSR intake form linked from your privacy policy, account settings page, and site footer. Map every system that holds customer personal data — CRM, OMS, ESP, CDP, helpdesk, analytics, payment logs — so you know where to search when a request arrives. Assign a DSR coordinator with a defined SLA and escalation path for complex requests. Build identity verification into the intake flow to confirm the requester is the Data Principal before disclosing or erasing any data. Log all DSRs — date received, nature of request, steps taken, date completed — as evidence of compliance in the event of a Board inquiry. For deletion requests, create a cascade deletion checklist covering all downstream systems including backup snapshots. Document what is retained for legal or regulatory reasons (financial records for GST, for example) and under what authority. Automate Your DPDP Compliance — Start Free on Consiva.ai Consiva.ai handles consent management, DSR workflows, ROPA generation, and breach notifications in one platform — purpose-built for Indian businesses. No credit card required to get started. Start Free — No Credit Card Required Checklist Item 04 CERT-In Breach Notification Readiness (6-Hour Rule) What It Means India's Computer Emergency Response Team (CERT-In) Directions of 2022 — which remain in force alongside the DPDP Act — require all entities to report cybersecurity incidents to CERT-In within six hours of detection. The DPDP Act additionally requires notification to the Data Protection Board and affected Data Principals of personal data breaches. Effective compliance means being able to detect, assess, and initiate notification within 72 hours of a breach — a very short window for an organisation that has not planned for it in advance. Why It Matters E-commerce platforms are high-value targets for attackers — your customer database contains PII combined with purchase history, which is extremely marketable on dark-web forums. A breach response that kicks off with "let's figure out what happened" on Day 1 is never going to hit a 72-hour notification deadline — and the regulators know it. Worldwide, we see that organisations which self-report quickly and can show they've got a handle on the situation get off much easier than those who drag their heels or try to keep it under wraps. How to Implement Enable real-time alerts from your Cloud setup (we're talking AWS GuardDuty, Azure Defender, or the equivalent) and your Web Application Firewall to let you know about any fishy data-access patterns. Define

breach severity tiers internally — not every security incident is a personal data breach requiring Board notification, but you need a documented decision tree to make that call quickly under pressure. Appoint a Breach Response Lead with authority to convene the response team and trigger formal notifications without waiting for multi-level board approval. Sort out pre-drafted notification templates for the Data Protection Board, CERT-In, and any data principals who might be affected — that way you can use those 72 hours wisely to investigate and contain the issue, not scrambling around to get a notification written from scratch. Run a tabletop exercise on your detection-to-notification pipeline at least once a year to test it out and make sure you'd actually be able to send out a notification if the worst happened — and update your breach response plan with any lessons you learn from it.

Checklist Item 05 Vendor / Processor Data Processing Agreements (DPAs) What It Means

The DPDP Act treats vendors who process personal data on your instructions as Data Processors . You, as the Data Fiduciary, remain responsible for ensuring that processors handle data in accordance with the Act. This requires a written contract — a DPA — that defines what data the processor can access, for what purpose, retention limits, security requirements, and sub-processor restrictions. Without DPAs, your processors' mishandling of customer data is legally your problem. Why It Matters A typical mid-size D2C brand uses 30 to 60 SaaS tools — logistics APIs, email service providers, payment aggregators, customer support platforms, marketing automation, analytics dashboards, and loyalty engines. Every one of these tools that touches personal data of your Indian customers is a Data Processor under the DPDP Act. A single logistics partner that fails to secure shipment data creates regulatory liability for your brand, not just theirs. How to Implement Build a vendor data inventory: list every tool, what personal data categories it receives, and the legal basis for that transfer. Review existing vendor contracts for data protection clauses — most legacy agreements predate DPDP and are wholly insufficient. Add an extra DPA addendum for every processor that handles personal data for Indian customers. The main parts are: using data only for the stated purpose, keeping data safe under security duties that match ISO 27001 or a similar standard, getting your approval for any sub-processor, telling you about a breach within the set time, and deleting the data when the contract ends. Focus first on processors with higher risk. This includes payment gateways and logistics partners. Also include any vendor that can see large volumes of customer records, and those who process sensitive categories — like health data for wellness brands, or financial data when there are BNPL integrations. Track DPA renewal dates alongside vendor contract renewals — a lapsed DPA is as problematic as no DPA at all. See also: how to map data flows for DPDP compliance . Checklist Item 06 Data Minimisation Principle (DPDP Section 4(1)(b)) What It Means Section 4(1)(b) of the DPDP Act establishes that personal data must be collected only to the extent necessary for the specified purpose. This is the data minimisation principle — a direct constraint on the habit of collecting as much data as possible “because it might be useful later.” For online shops, start by checking the parts of the site where you ask for info. Look at the checkout page, the sign-up steps, and any

marketing settings page. Remove fields that you do not truly need for the reason you say you are collecting the data.

Why It Matters

Taking too much data can raise your risk. If you do not store a type of data, there is less to lose in a breach. It also cannot be used in ways you did not plan. This can cut down on regulatory worry. It can also lower how much data you have to keep. In many cases, it helps the stored data stay more accurate. Teams that use data minimisation often handle data subject requests faster. They also see a smaller impact when something goes wrong. That helps day to day work and it helps with legal needs.

How to Implement

Go through each place where data is gathered. Include the checkout form, the account sign-up page, wishlists, loyalty sign-ups, review forms, customer support ticket fields, and exit-intent prompts. For each field collected, document the specific processing purpose it serves. If no clear purpose can be documented, remove the field from the form. Remove optional fields that add friction and serve no documented purpose — for instance, date of birth on a fashion D2C site with no age-restricted products or loyalty birthday benefits. Review CRM custom fields — most brands accumulate dozens of fields over time that no team actively uses or reports on. Adopt a data-minimisation review as standard practice for new features: before the engineering sprint starts, ask “what personal data does this feature need, and why?” Make the answer part of the sprint brief.

Checklist Item 07 Retention Policy and Deletion Schedule (DPDP Section 8(7))

What It Means

Under Section 8(7) of the DPDP Act, Data Fiduciaries must delete personal data once the reason for collecting it is met. They also have to make sure their processors delete it too. An exception exists when the law says the data must be kept longer. This is a big shift from the old habit of holding onto customer data forever, just in case. You should have a written data retention plan. It must say how long each type of data is stored and what event starts the deletion.

Why It Matters

Some e-commerce brands keep customer records for years, even after there is no clear business need. The same data can be found in live databases, email lists, and backup or offline storage. That kind of stash can turn into a risk if it is exposed. Your retention rules should also cover backups, system logs, and analytics event records, which are often overlooked.

How to Implement

Set retention by data category: transaction records (order history, invoices) — 7 years is standard for tax and GST compliance; customer PII in marketing systems — 3 years after last purchase is a common rule; cookies & tracking data — 13 months is a good benchmark. Document any legal holds that override your standard deletion process — data involved in active litigation, regulatory inquiries, or tax scrutiny needs to be kept until the hold is lifted. Automate deletion where possible — most CRM and ESP platforms support automated list suppression and record deletion based on configurable date rules. Include your Records of Processing Activities (ROPA) in the retention review cycle — ROPA entries should reflect the actual retention timelines in practice, not just on paper. Document and test deletion procedures quarterly, especially for backup and disaster-recovery systems where data persists beyond primary-system deletion timelines.

Checklist Item 08 Children’s Data Check — Under-18 Verification (DPDP Section 9)

What It Means

Section 9 of the DPDP Act imposes heightened obligations before

processing the personal data of children — defined as persons under the age of 18. The Act requires verifiable parental consent before collecting a child's personal data, and prohibits processing that could cause harm to a child's wellbeing, including tracking and behavioural advertising directed at children. This is a hard legal obligation with significant penalties for violation, not a soft guidance note.

Why It Matters Many D2C categories — toys, kids' apparel, educational products, gaming, and general fashion — have substantial under-18 user bases. If your site allows under-18 users to create accounts, purchase products, or interact with personalisation features without age verification and parental consent, you are processing children's data without a valid legal basis. Additionally, deploying behavioural advertising pixels without verifying that the user is not a child creates separate exposure under Section 9(3).

How to Implement Assess honestly whether your product or category is attractive to under-18 users. If the answer is yes, implement age-gate mechanisms at account creation and checkout flows. For verified minor users: disable behavioural advertising pixels and suppress data from being shared with advertising platforms and retargeting systems. Build a parental-consent workflow for brands where parents need to approve their child's account — especially relevant for edtech, gaming, and specialist kids' brands. Go through your CRM and check for any records with DOBs that indicate someone is under 18 — add some extra protections to those records and get them out of any behavioural marketing segments right away. Get your marketing team up to speed on what it's not okay to do — train them on what constitutes targeting kids, and put together a pre-campaign checklist that includes verifying the age of the audience before kicking off any new campaign. If you can't do good age verification in your current setup, consider restricting account creation to people 18 and over at sign-up — that's a decent stopgap.

Checklist Item 09 Employee Training Program What It Means The DPDP Act's obligations fall on the organisation as a Data Fiduciary, but data protection failures are almost always caused by people — phishing attacks that succeed because employees click links, customer data exported to personal drives, privacy-invasive product features shipped without a privacy review. A training programme is not a tick-box exercise; it is the primary mechanism for converting legal requirements into consistent employee behaviour across the organisation.

Why It Matters Regulators globally treat the existence and quality of employee training as a significant mitigating factor in enforcement actions. An organisation that can demonstrate a structured training programme, track completion rates, and show that employees understood their obligations will be treated more leniently after a breach than one with no training record at all. Training also reduces incident frequency — making it a risk-management investment, not just a compliance cost.

How to Implement Create role-based training programmes: the all-staff basic training should cover the basics of data protection, phishing awareness and handling customer data right; your marketing team should get training on what consents you need, pixel stuff, and the rules around audience segmentation; the engineers should learn about privacy by design, coding securely, and what data to leave out when developing new features; and your customer support team should know how to handle DSR requests and

verify identities before giving any customer info out. Run mandatory training at onboarding and annually thereafter, with a short assessment to confirm comprehension — not just completion. Use real-world scenarios from your own category — e.g., “a customer calls asking to delete their account; what do you do next?” — rather than generic hypothetical case studies. Document completion records and assessment scores. These records become evidence of due diligence in a regulatory inquiry or Board audit. Name a Data Protection Point of Contact. This person should handle internal escalations, update the training materials when the DPDP Rules change, and act as the main link if the Data Protection Board needs to be contacted.

Checklist Item 10 Breach Response Plan What It Means

A Breach Response Plan, or BRP, is the internal guide used right after someone flags a possible personal data breach. It spells out roles and tasks, and it names who should reach out to whom. It also covers how to check what happened, what to do to limit further spread, and the point at which notifications need to be sent. After the incident is over, it lists the next steps too. This is not the same as an IT recovery plan that mainly aims to bring systems back online. A BRP is built for the legal and compliance duties that follow a breach. That includes the 72-hour notification timeline and the need to notify the people whose data was affected.

Why It Matters

When there is no BRP, the response happens in a rush and often under stress. People end up debating ownership of tasks. Legal advice may arrive too late to be useful. Decisions about alerts and messages can drag on. In some cases, the required time window passes and the organization is left exposed. Not notifying adds more risk than most teams expect. It can also worsen trust damage when the public sees a messy and unready effort. A practiced BRP helps keep the response steady, with records and clear steps.

How to Implement

First, set up a breach response group and assign roles in plain terms. Engineering handles containment and evidence collection. Legal or Compliance makes notification calls and stays in contact with the right regulators. Communications prepares messages for customers and any public updates. Customer Support deals with questions from affected users. Build a severity matrix. Match each incident type to the notification duties it triggers. Not every security event triggers DPDP Board notification, but you need a documented decision framework to make that determination within 24 hours of detection. Pre-draft notification templates for: the Data Protection Board, CERT-In, affected Data Principals by email and SMS, and a holding public statement for media enquiries. Establish secure out-of-band communication channels for the response team — if your primary email system is compromised, you need an alternative coordination channel ready to use. Run a tabletop exercise simulating a realistic breach scenario at least annually. Update the BRP based on lessons learned from each exercise and from any real incidents.

Checklist Item 11 Records of Processing Activities (ROPA) What It Means

A Record of Processing Activities, or ROPA, is a list kept inside your organisation. It covers every process where personal data is handled. For each entry, the record notes: what kind of personal data is used, why the data is processed, the legal reason for doing it, who is affected (the data subjects), who does the work as a processor, which recipients get the

data, whether any data goes across borders, and how long the data will be kept before it is deleted or disposed. While the DPDP Act does not use the GDPR's explicit "ROPA" terminology, the accountability obligations and the Data Protection Board's broad audit powers make an equivalent internal record essential for demonstrating compliance at any point. Why It Matters When the Data Protection Board is on your case and demanding evidence of your data-protection practices, your Record of Processing Activities is the one document that shows for sure you've taken the time to get a handle on what you're doing with personal data. For e-commerce businesses, a ROPA usually ends up covering 15 to 30 different processing activities — once you've gone through and documented the ins and outs of things like marketing, logistics, payment processing, customer service and analytics. And let's be honest, trying to build this from scratch when the auditors are breathing down your neck is just plain tough. See our guide on automating your ROPA for DPDP compliance .

How to Implement Kick things off with a data-flow mapping exercise — sit down with the people in charge of each business area (marketing, logistics, finance, customer support and IT) and get them to tell you what kind of personal information each of their teams are collecting, using, sharing and hanging onto. Use a ROPA template that's been laid out in a way that makes sense, so you can be sure you're capturing everything you need. Consiva.ai generates and maintains your ROPA automatically as part of the compliance workflow, reducing the manual maintenance burden significantly. Assign ROPA ownership: each processing activity should have a named business owner responsible for keeping that record current and accurate. Review the ROPA quarterly and whenever a new processing activity is introduced — a new marketing channel, a new logistics partner, or a new analytics tool all require new or updated ROPA entries. Cross-reference your ROPA against your privacy notice — every processing activity documented in the ROPA should correspond to a disclosure in the notice visible to Data Principals. Gaps in either direction require immediate remediation.

Checklist Item 12 Annual Privacy Audit What It Means A privacy audit is a way to see how well your group handles personal data. The goal is to see if you meet the DPDP Act rules. You should do it at least one time each year. You should also redo it after major changes — think of a big product release, a purchase or merger, moving into a fresh market, or a serious data breach. During the audit, you look at your safeguards. First, you confirm they are in place. Then, you test that they actually work in daily use. You also check whether they still fit your current way of doing business. When the audit ends, you receive findings. Next, you turn those findings into a plan for fixes. The plan names who must handle each item, sets dates to finish the work, and reserves money for the updates. Why It Matters Compliance is not a one-time project — it is an ongoing state that requires active maintenance. An e-commerce brand that completed a DPDP compliance exercise and has since launched new product lines, onboarded new SaaS vendors, and migrated to a new customer data platform without revisiting its compliance posture is almost certainly out of compliance in several material respects. The annual audit is the governance mechanism that catches and corrects this drift before it becomes a regulatory problem. How to

Implement Schedule the audit on a fixed calendar date with executive sponsorship — not “when we have bandwidth,” because that day rarely arrives without a committed schedule. Use the 12-item checklist above as the baseline audit scope, supplementing with any Significant Data Fiduciary obligations that apply to your organisation’s scale and data volumes. Bring in an outside privacy specialist or a well-trained auditor to do the yearly check. Your in-house reviews can help you stay alert, but rule makers usually ask for something that stands on its own. Write up the audit results as a formal report. Include a list of issues with risk ratings, and add a remediation plan that has dates and names for who owns each fix. Send the findings to your senior leaders or board. Privacy and data handling issues touch the entire company — it is not only a back-office compliance item. When leaders can see the issues, the fixes tend to move faster. Find out if your size and how much data you process makes you a Significant Data Fiduciary . If yes, you must meet more duties. This can include having a DPO and running Data Protection Impact Assessments.

Putting It All Together: DPDP Compliance Roadmap The twelve items above are meant to work as a full system. Do not treat this like a form you complete one time. It needs real owners, ongoing maintenance, and routine follow-ups as time goes on. Most e-commerce and D2C companies should follow a practical order. The pragmatic sequence: start with what’s customer-visible and legally required, then work outward to governance. Start with consent and the privacy notice, since customers see these first and the law expects them early. Then set up your DSR process and your breach response plan, since they are the most urgent day-to-day needs. After that, review vendor DPAs, ROPA, and staff training. Finally, plan the yearly audit to keep the controls current and to keep the process fair.

Priority Action for This Month Audit your consent banner. Test your site with a cookie scanner. Find every third-party script that runs before consent is collected. Stop those scripts from loading until consent is given, or use a CMP that matches the rules. Doing only this can cut the most obvious risk right away and shows you are acting quickly. Consiva.ai’s free plan includes a full cookie audit and consent banner setup — no credit card required to begin. If you are operating at scale with millions of registered customers, also assess whether you qualify as a Significant Data Fiduciary under the DPDP Rules — a designation that carries additional obligations including mandatory Data Protection Officer appointment, Data Protection Impact Assessments, and annual independent audits. Our detailed guide on DPDP compliance for high-growth companies covers the Significant Data Fiduciary threshold and what it means for your compliance programme. And if you are looking to move beyond manual spreadsheet-based compliance tracking, explore our guide on automating your ROPA and the broader compliance workflow with Consiva.ai. Compliance infrastructure built now will be a competitive advantage — customers increasingly choose brands that treat their data with visible care and accountability. See our pricing plans or talk to a compliance expert to get started. Your DPDP Compliance Command Centre Consiva.ai brings together consent management, automated ROPA, DSR workflow automation, breach notification templates, and vendor DPA tracking — purpose-built for Indian e-commerce and D2C

brands. Get started free and see how compliance can become a competitive advantage rather than a cost centre. Get Started Free Or speak with a compliance expert to discuss your specific requirements. See pricing plans . Frequently Asked Questions Is the Digital Personal Data Protection Act 2023 already in force for e-commerce businesses? + Yes it is. The Digital Personal Data Protection Act 2023 got the president's seal of approval back in August 2023, and the DPDP Rules 2025 were put out on 13 November 2025 (G.S.R. 846(E)) — all the extra details needed to make sure it goes into practise. E-commerce platforms that process personal data of Indian customers should treat compliance as immediately necessary — enforcement is active, not upcoming. What is the penalty for non-compliance with the DPDP Act for e-commerce companies? + The DPDP Act prescribes financial penalties of up to ₹250 crore per violation category for failure to implement reasonable security safeguards, and up to ₹200 crore for failure to notify the Data Protection Board of a personal data breach. Penalties are assessed per category, not per individual affected. For e-commerce brands with large customer databases, cumulative exposure across categories can be substantial — and this is before accounting for reputational damage, customer churn, and potential claims from affected individuals. Do D2C brands selling only within India need to comply with DPDP? + Yes. The DPDP Act applies to any Data Fiduciary that processes digital personal data of individuals in India, regardless of whether the business operates locally or internationally. D2C brands collecting even basic information such as name, phone number, email address, delivery address, and purchase history from Indian customers are fully in scope. There is no general exemption for small businesses in the current text of the Act, although the Rules may introduce a phased applicability approach for micro and small enterprises. How do we handle consent for users who already gave consent before the DPDP Act? + The DPDP Act requires that consent obtained before its commencement must be brought into conformity within a period specified by the Rules. Practically, this means e-commerce brands should run a re-consent campaign for their existing user base using notices that meet DPDP standards — specific purpose, granular options, and an unambiguous affirmative action. Consiva.ai makes it easy to automate re-consent campaigns with full records, allowing you to get a compliant system up and running — even while smoothing out any bumps in your marketing programs. What constitutes a personal data breach under the DPDP Act? + The DPDP Act considers a personal data breach to be any unauthorised mucking about with, spilling, changing or deleting of people's data. This includes a hacked customer database, accidental exposure of order records through a misconfigured API, or a rogue employee exfiltrating customer PII. All such incidents must be evaluated against the 6-hour CERT-In notification requirement and reported to the Data Protection Board as prescribed. Your internal breach-severity matrix (Checklist Item 10) should provide documented criteria for making this determination quickly under pressure. Does the DPDP Act stop e-commerce businesses from sending data across borders on global cloud services? + Well — the DPDP Act does allow the Indian govt to put a stop to personal data being sent to listed countries, if it decides that's necessary. Until the

Government publishes a negative list of restricted destinations, cross-border transfers are generally permitted subject to appropriate contractual safeguards with processors. E-commerce brands using global CDNs, payment processors, or logistics SaaS platforms should review their Data Processing Agreements and monitor MeitY announcements closely for any transfer restrictions that may be notified. Related Posts Data Discovery How to Map Your Data Flows for DPDP Compliance Consiva Editorial · May 2026 DPDP Compliance DPDP Compliance for SaaS Companies: Significant Data Fiduciary Guide Consiva Editorial · May 2026 Automation How to Automate Your ROPA for DPDP Compliance Consiva Editorial · April 2026 Stay Ahead of DPDP Developments Practical compliance updates, checklist tools, and DPDP Act analysis delivered to your inbox — no spam, unsubscribe anytime. I agree to receive DPDP compliance updates and consent to Consiva processing my email for this purpose. Privacy Policy . Subscribe India's DPDP compliance platform and consent management software — built natively for DPDP 2023, CERT-In, and global privacy frameworks. DPDP 2023 CERT-In GDPR Made in India 🇮🇳 ISO 9001 Certified ISO 27001 Certified NASSCOM Member DSCI · DSCI/AM/2026/089 DPIIT Recognised Privacy contact (Rule 9): Saurabh K, Privacy Officer & Grievance Officer saurabhk@swaransoft.com DPDP Knowledge DPDP Act 2023 DPDP Rules 2025 Data Fiduciary Obligations Data Principal Rights & Duties Retention & Erasure Penalties & Enforcement Compliance Blog Privacy Blueprint Industries SaaS & IT D2C & E-commerce BFSI Healthcare EdTech Startups Digital Marketing Agencies Trust & Legal Privacy Policy Terms of Service Cookie Policy Acceptable Use Policy Support Policy Privacy Rights & Grievance Refund & Cancellation Disclaimers & AI Notice Contact & Routing Company About Us Pricing Blog FAQ Contact Sitemap Login → Ask AI About Consiva Get an instant AI-generated overview Open your favorite AI assistant with a ready-made prompt about Consiva ChatGPT Perplexity Claude Google AI Grok © Consiva.ai · A product of Swaran Soft Support Solutions Private Limited CIN: U72200DL2005PTC136405 · GSTIN: 06AAJCS7515G1Z9 Tower A, Unit No. 2, 2nd Floor, The Cityscape, Sector-66, Golf Course Extension Road, Gurugram, Haryana – 122102, India support@consiva.ai · +91 9220313650 · ISO 9001:2015 & ISO/IEC 27001:2022 certified management systems within the scope of providing software development services.

64. What Is Data Discovery and Why Every DPDP-Regulated Business Needs It | Consiva.ai

Source URL: <https://consiva.ai/blog/data-discovery-dpdp-compliance>

What Is Data Discovery and Why Every DPDP-Regulated Business Needs It | Consiva.ai ↑ ISO 9001 Certified · ISO 27001 Certified · NASSCOM Member · DSCI Member · DSCI/AM/2026/089 · DPIIT Recognised · Download White Paper Home Platform Platform Overview See the whole operating model — every module, one dashboard Consent & Notice Consent Management Platform Purpose-specific consent with signed, exportable records Cookie Consent Management Scans every cookie and tracker, including ones you didn't add DPDP and GDPR

Consent Already run a GDPR CMP? What changes for DPDP Rights & Grievance Data Principal Rights Management Access, correction, erasure, grievance and nomination DSAR Management Software DSAR vs Data Principal request, explained Discovery, Mapping & Records Data Discovery Software Find personal data at rest, column by column Data Mapping Software Purpose-mapped data inventory from discovery findings ROPA Software A Records of Processing Activities register with source attribution Breach & Incident Data Breach Management CERT-In 6-hour and DPDP Rule 7 clocks, tracked independently Governance Processor & DPA Register Vendor DPA status, risk tiers and expiry alerts DPDP Knowledge DPDP Act 2023 Scope, definitions & key provisions of the law DPDP Rules 2025 Commencement dates & Rule-by-Rule breakdown Data Fiduciary Obligations Notice, consent & lawful processing under §§4–10 Data Principal Rights & Duties Your 4 rights & 5 duties as a data subject Retention & Erasure Rule 8: when to hold data and when to delete it Penalties & Enforcement Full penalty schedule — up to ₹250 Cr per violation FAQ Common questions about DPDP and Consiva Industry SaaS & IT Dual Fiduciary & Processor roles, offshore transfers D2C & E-commerce 2 Cr threshold, purchase consent & 3-year clock BFSI RBI & PMLA retention, defaulter data exemption Healthcare Fourth Schedule carve-out & patient data handling EdTech Rule 10 parental consent & child data protection Startups §17(3) exemptions & lean compliance playbook Digital Marketing Agencies Tag stack liability, Processor vs Fiduciary clarity Blog Pricing Contact Login → Dark Data Privacy 9 min read What Is Data Discovery and Why Every DPDP-Regulated Business Needs It Automated data discovery is the invisible foundation beneath every DPDP obligation — from accurate ROPA records to 30-day erasure fulfilment under Section 12. If you do not know where personal data sits, you cannot safeguard it, remove it, or show proof of compliance to the Data Protection Board of India. CE Consiva Editorial Team 15 May 2026 2,100 words DPDP 2023 Act covered Home › Blog › Data Discovery & DPDP Compliance On This Page What Is Data Discovery? Foundation of DPDP Compliance PII Scanning Across Databases Structured vs Unstructured Data How Discovery Feeds ROPA Section 12 Erasure Requests Running Your First Scan What to Do With Results Consiva's Discovery Module Cost of NOT Discovering Data Frequently Asked Questions Data Discovery DPDP Act 2023 PII Scanning ROPA Section 12 Data Mapping Privacy Compliance What Is Data Discovery? Data discovery is the step where teams look for personal data across their systems. It is often done with automation that scans and flags data, then lists it in a catalog. This covers places like databases, file servers, cloud drives, APIs, and tools from outside vendors. So the main goal is simple to say. You want to know where the personal data lives, in real terms. The idea can sound easy. But it can turn into a mess quickly. Take a medium sized company in India. It might see roughly ten thousand customer orders each month. That work can leave personal data scattered in all sorts of places. There could be a MySQL database still running. There may be an older SQL Server setup. Staff might rely on an Excel sheet saved in a shared Google Drive. Some details can also sit inside a helpdesk ticket tool. Then there is the marketing automation platform too. Without systematic discovery, none of that is visible — and invisible data cannot be protected, deleted, or reported to the Data Protection Board of India. Data

discovery is not a one-time audit exercise. The most effective programmes treat it as a continuous, automated process that runs on a schedule — flagging new personal data stores as they appear, tracking changes to existing ones, and maintaining a living inventory that reflects the reality of your systems rather than a snapshot from six months ago.

Active vs Passive Data Discovery

There are two main ways to locate personal data. Knowing how they differ can change how you plan your DPDP work. Active scanning gives ground-truth inventory; passive analysis maps how data flows. The best programmes use both.

Active discovery is a method where you reach out to the places where data lives. You use read-only database logins or storage access keys. Then you run set queries or you move through folders in the file system. During this step, the tool looks at field or column names. It also checks a few sample values. Then it applies match rules to tag the text. These rules may use regular expressions for Aadhaar IDs, PAN card numbers, email addresses, and phone numbers. Active scanning produces high-confidence, precise results because it examines actual data rather than traffic metadata.

Passive discovery analyses network traffic, database audit logs, or application access logs to infer what personal data exists and how it flows between systems — without accessing data stores directly. It is useful for discovering shadow data paths and understanding data flow diagrams, but it cannot replace active scanning for classification accuracy. The best compliance programmes use both: active scanning for ground-truth inventory, passive analysis for data flow mapping. Modern automated data discovery platforms — including Consiva's built-in scanner — combine active database interrogation with passive log analysis, giving you a complete picture of your data landscape within hours rather than the weeks a manual spreadsheet audit would require.

Why Data Discovery Is the Foundation of DPDP Compliance

The Digital Personal Data Protection Act 2023 (DPDP Act) introduced India's most comprehensive data privacy framework. It places a broad set of obligations on Data Fiduciaries — any organisation that determines the purpose and means of processing personal digital data. Every one of those obligations traces back to a single precondition: you must know what personal data you hold and where it is.

DPDP Act Provisions That Require Data Discovery

Section 4: Processing only for lawful purpose with consent — impossible to audit without a comprehensive data inventory.

Section 6: Purpose limitation — data retained beyond its stated purpose cannot be identified without a discovery index.

Section 8(4): Reasonable security safeguards — you cannot secure data you do not know exists.

Section 8(5): Data Fiduciaries must ensure personal data is complete, accurate, and consistent — requires a master inventory.

Section 8(6): Breach notification to the Board — you cannot notify on a breach of data that was never inventoried.

Section 8(7): Erasure of data after purpose fulfilment or consent withdrawal — demands knowing every storage location.

Section 9: Children's data protections — requires identifying whether child data is stored and where.

Section 12: Data principal rights including access, correction, and erasure — all responses require a precise data map. Think of data discovery as the geological survey you commission before constructing a building. Without knowing what lies beneath — soil composition, buried utilities, drainage channels — every subsequent construction step is guesswork. DPDP compliance built without a data discovery foundation will eventually fail when

the Data Protection Board sends an inquiry notice and your team cannot account for where a data principal's information resides. The DPDP Act's emphasis on purpose limitation under Section 6 means that data should not be retained beyond what is necessary for the stated purpose. But you cannot enforce purpose limitation on data you do not know exists. Orphaned records in decommissioned databases, test environments seeded with production data, and forgotten analytics pipelines are all common sources of undiscovered personal data — and all represent potential regulatory liabilities.

How PII Scanning Works Across SQL Server, MySQL, and PostgreSQL

Personally Identifiable Information (PII) scanning — the technical core of automated data discovery — works differently depending on the database platform. Here is how a production-grade scanner handles the three most common relational databases in Indian enterprise environments.

Microsoft SQL Server Consiva talks to SQL Server through a special user account that only reads data — a read-only service account to be exact. Before starting the scan, the software first takes a look at every database on the instance, and maps out all the tables and columns in it by querying the `INFORMATION_SCHEMA.COLUMNS` view. Then it runs a two-stage analysis: first, it looks through the column names for certain patterns — things like 'email', 'mobile number', 'aadhaar number', 'pan card', 'date of birth', and loads of others like that. If it finds one, it labels that column as likely sensitive. After that, it grabs a smaller batch, usually around 500 to 1,000 rows. It picks records from the fields that are likely to hold PII. Then it applies a regular expression to the sample. This step is meant to verify whether any sensitive values are present.

– Consiva column heuristic discovery query (simplified)

```
SELECT TABLE_SCHEMA, TABLE_NAME, COLUMN_NAME, DATA_TYPE, CHARACTER_MAXIMUM_LENGTH FROM INFORMATION_SCHEMA.COLUMNS WHERE COLUMN_NAME LIKE '%email%' OR COLUMN_NAME LIKE '%mobile%' OR COLUMN_NAME LIKE '%aadhaar%' OR COLUMN_NAME LIKE '%pan_card%' OR COLUMN_NAME LIKE '%passport%' OR COLUMN_NAME LIKE '%dob%' OR COLUMN_NAME LIKE '%address%' OR COLUMN_NAME LIKE '%pincode%' ORDER BY TABLE_SCHEMA, TABLE_NAME, COLUMN_NAME;
```

MySQL and MariaDB MySQL scanning follows the same column-heuristic approach but additionally inspects table comments and column comments — metadata fields often populated by developers with plain-language notes such as “stores customer PAN number for tax processing”. The scanner checks what comes from `SHOW CREATE TABLE`. It looks at `CHECK` constraints and uses them to see how values are stored. This can help confirm if a column holds structured PII, like Aadhaar, which is a 12 digit number, or email addresses.

Consiva's MySQL connector can work with both MyISAM and InnoDB. It also allows encrypted links using TLS.

PostgreSQL PostgreSQL introduces two additional discovery vectors that make it particularly interesting: custom types and JSONB columns. A column of a custom type named `user_gender` defined as an ENUM is clearly sensitive personal data even if the column name itself is an opaque abbreviation. Consiva's PostgreSQL connector queries `pg_type` and `pg_enum` to surface these custom types and flag them for human review. It also scans JSONB columns — an increasingly common storage pattern in modern applications — by extracting a sample of JSON objects and analysing their key names against the PII heuristic dictionary. â A

2025 survey of Indian SaaS companies found that 63% of discovered personal data resided in tables whose names gave no indication of containing PII — order history tables holding delivery addresses, event log tables capturing IP addresses, and analytics tables storing device fingerprints. Column name heuristics alone are insufficient; data value sampling is essential for high-confidence classification.

Structured vs Unstructured Data Discovery

The distinction between structured and unstructured data is one of the most consequential in data discovery, because the two require entirely different scanning approaches and present different compliance risk profiles under the DPDP Act. Structured data lives in relational databases, data warehouses, and spreadsheets with defined schemas. SQL Server, MySQL, PostgreSQL, Amazon Redshift, Google BigQuery — all are structured sources that yield to the column-heuristic and data-sampling approach described above. They are the easiest to scan because they have predictable column names and typed values. Unstructured data is harder to manage for compliance. You can find it in many places, like PDF files with signed contracts or KYC papers in cloud storage. There are also Word and Excel files with customer lists or staff records. Some teams keep email attachments in shared inbox archives. Identity documents may show up as images, then get run through OCR. Chat histories and support tickets can be saved as plain text in NoSQL tables. Web server logs are another issue, since they may store personal info inside URLs or in request data.

Characteristic	Structured Data	Unstructured Data
Scanning approach	Schema traversal + data sampling	OCR, NLP, and regex on file content
Scan speed	Fast	Moderate
Classification confidence	High	Medium
DPDP regulatory risk	Medium	High
Common sources	MySQL, SQL Server, PostgreSQL, Redshift	S3 buckets, SharePoint, email archives, PDF stores
Erasure complexity	Row-level DELETE statements	File deletion or content redaction

For DPDP compliance, unstructured data presents the greatest regulatory risk precisely because it is the hardest to inventory and control. A scanned Aadhaar card stored in an Amazon S3 bucket without proper access controls is a serious data breach waiting to happen — and without unstructured data discovery, your privacy team will never know it exists. Consiva scans both structured and unstructured sources in the same unified workflow, surfacing a single data map across your entire technology estate.

How Data Discovery Feeds into ROPA Generation

The Record of Processing Activities (ROPA) is the cornerstone compliance document for any Data Fiduciary operating under the DPDP Act. While the Act itself does not use the specific term ROPA, Section 28 empowers the Data Protection Board of India to requisition records detailing how personal data is being processed — making a well-maintained ROPA the obvious evidence to produce in response to any Board inquiry. A ROPA entry for any given processing activity must capture: the category of personal data processed, the purpose of processing, the legal basis (consent under Section 6, legitimate use under Section 7, or a specific exemption under Section 17), the data retention period, the technical and organisational security measures in place, and — critically — the systems and locations where the data is stored. Without data discovery, this last field is filled by guesswork or incomplete self-reporting from application owners who may not know the full scope of what their systems store. 💡 With automated discovery, your ROPA's storage location field is populated from verified scan results rather than

developer recollections. When the Board asks “where do you store customer email addresses?”, your answer is backed by evidence — not memory. This distinction is the difference between a convincing compliance demonstration and an uncomfortable audit conversation. In practice, Consiva’s data discovery scanner runs an active scan across your connected data sources and produces a classified inventory — listing every storage location, the category of personal data found there (contact details, financial data, biometric data, health data, and so on), and the confidence level of the classification. This inventory is ingested by Consiva’s ROPA module, which maps each storage location to the relevant processing activity and auto-populates the Systems and Storage field. The result is a living ROPA that updates whenever a new scan detects a change — a new table added to your database, a new S3 prefix created by an ETL pipeline, or a new SaaS connector introduced by your sales team. You no longer rely on developers self-reporting data structures to the privacy function. For a deeper look at the full ROPA workflow, see our guide to automating ROPA for DPDP compliance .

Know Exactly Where Your Personal Data Lives

Consiva’s automated discovery scanner maps your databases, cloud storage, and file systems in hours — not weeks. No manual spreadsheets. No guesswork. Results feed directly into your ROPA and rights fulfilment engine. [Start Free on Consiva.ai — No Credit Card Required](#)

How Data Discovery Enables Section 12 Erasure Request Fulfilment

Section 12 of the DPDP Act, 2023 gives data principals a right to ask for deletion of their personal data. This covers your customers, your workers, and also any other person whose data you handle. In Section 12(b), the Act is clear about when erasure can be sought. It applies when the personal data is no longer needed for the reason it was gathered. It also applies when the person withdraws consent. The Data Protection Board, once fully operational, is expected to formalise a fulfilment deadline; international best practice and draft rules suggest a window of 30 days from receipt of the request. Consider what happens when an erasure request arrives in your privacy team’s inbox without a data discovery system in place. The team manually contacts each application owner, asking them to search their respective systems. The marketing manager checks the CRM. The engineering lead queries the production database. Nobody checks the data warehouse, the email marketing platform, the CSV export generated for a now-cancelled campaign, or the backup snapshots retained in cloud storage. The individual’s personal data persists in at least three locations. If the Board audits this deletion, you have a demonstrable compliance failure — one that could attract a penalty of up to ₹50 crore under Schedule I of the Act. With Consiva’s discovery-backed data map, the erasure workflow is entirely different and reliably complete:

- 1 Erasure request received and logged A data principal submits an erasure request via your Consiva-powered rights management portal or by email. Consiva creates a timestamped ticket with the request date, the individual’s identifiers (email address, customer ID, or phone number), and the calculated fulfilment deadline — 30 days from the date of receipt.
- 2 Automated data location lookup Consiva queries its discovery index — the continuously updated inventory of all personal data across your connected systems — and retrieves every storage location associated with the individual’s identifiers. This runs in seconds and produces a complete deletion checklist.
- 3 Assisted or automated deletion execution Depending on your

configuration, Consiva either generates deletion scripts for your engineering team to execute with one-click approval (maintaining human oversight), or for connected SaaS systems triggers deletion directly via the system's API. Each deletion action is logged with a UTC timestamp, the identity of the approver, and the specific records deleted.

4 Verification scan and formal closure

A targeted re-scan of the identified locations confirms that the data no longer exists in any of the flagged stores. Consiva closes the ticket and generates a fulfilment certificate — a PDF audit trail including all deletion logs, timestamps, and approver identities — which you can produce to the Board or to the data principal upon request. The entire process is documented end-to-end, well within the 30-day window. Without the discovery foundation, step 2 is simply absent. That absence makes the remaining steps unreliable and almost certainly incomplete — a risk no Data Fiduciary under the DPDP Act should be prepared to accept given the Board's enforcement powers.

Running Your First Data Discovery Scan: Step by Step

Getting started with data discovery on Consiva is a structured process designed to minimise disruption to your production systems while maximising coverage. Here is a practical walkthrough of the full first-scan cycle.

1 Inventory your data sources before connecting anything

Set aside 30 minutes to jot down every system that might store personal data. Think about the production database first. Then check staging and development setups. Don't forget data warehouses, too. Also include third-party SaaS tools that move or store personal data, shared drive folders, and email archives. Look for outside APIs as well. Even if your list is not finished, you still get a clearer sense of what is in scope.

2 Create dedicated read-only service accounts

For each database, create a read-only user account exclusively for Consiva.

In MySQL: `GRANT SELECT ON . TO 'consiva_scan'@'%' IDENTIFIED BY 'strongpassword';`

In PostgreSQL: `GRANT CONNECT ON DATABASE mydb TO consiva_scan; GRANT USAGE ON SCHEMA public TO consiva_scan; GRANT SELECT ON ALL TABLES IN SCHEMA public TO consiva_scan;`

Never use an admin or application credential for scanning. Least-privilege access is both a security best practice and a requirement under DPDP Section 8(4).

3 Connect data sources in the Consiva dashboard

Head over to Settings → Data Sources → Add New. Choose the type of database you're working with and enter the host, port, database name and the read-only credentials you created at setup. Consiva tests the connection and confirms it works before it saves it. If you are linking cloud storage, supply an IAM role ARN (AWS) or a service account JSON (Google Cloud) to give Consiva read-only access to your bucket.

4 Configure scan parameters and PII categories

First, choose the scan depth you want: Schema-only (fastest results, lowest confidence), the full-on scan (all rows, slowest, highest confidence), or a simple Schema plus Sample (a 500-row data sample — the recommended starting point). Then decide which PII categories you want Consiva to flag — contact details, financial identifiers, government IDs (like Aadhaar & PAN), biometric references, health data, and location data. Set the initial scan to run right away, and schedule the subsequent incremental scans to run daily or weekly.

5 Review, validate, and act on results

The initial scan spits out a classified inventory with confidence scores — if the score is high enough, you can let Consiva auto-approve the findings. But if the score is only medium, you'll have to verify whether it's, say, an Aadhaar number or just an internal reference number (that ref_no

column with 12-digit numbers in it). Plan for about an hour or so of review time per 100 findings on the first run; subsequent scans only flag what's changed.

Classification, Tagging and Remediation of Discovery Results

Your job is to now take these findings and turn them into something useful. A completed data discovery scan is not itself a compliance deliverable — it is the raw material from which compliance is built. Raw scan results must be processed through three subsequent steps before they translate into materially reduced regulatory risk.

Classification: Assign Sensitivity Categories

Assign each discovered data element to a sensitivity category aligned with the DPDP Act's distinctions. Consiva fills in a set of categories ahead of time. It includes Basic Contact Data such as name, email, and phone number. It also includes Government Identifiers like Aadhaar, PAN, Passport, and Voter ID. There is Financial Data too — bank account numbers, card numbers, UPI IDs, and GSTIN. Health and Medical Data are listed as well — conditions, prescriptions, and diagnostic results. Biometric Data is another category, meaning fingerprints, face templates, and retina scans. Minors' Data is also included — any data for people under 18 years old — which must follow extra safeguards under Section 9, including a need for parental consent that can be checked. Next, classification is used to decide the legal basis for processing. It also helps set the right limits for how long data is kept. Classification points to the security controls that must be used. It also helps decide if the Data Fiduciary counts as a Significant Data Fiduciary under Section 10. If it does, more duties apply, including a Data Protection Impact Assessment.

Tagging and Ownership Assignment

Once classified, each data store should be tagged with a designated data owner — typically the business unit responsible for the system — and linked to the relevant processing activity in your ROPA. This ownership model ensures accountability: when a data principal submits a rights request or when a retention period expires, there is a named individual responsible for acting. Consiva's tagging interface allows bulk ownership assignment across all tables within a database, or granular column-level tagging for particularly sensitive fields.

Remediation: Act on What You Find

Many first-time discovery scans surface data that should not exist in its current form. Common findings include:

- Personal data in non-production environments: Replace with anonymised synthetic data using Consiva's masking templates.
- Production data seeded into staging or development environments is one of the most frequent causes of inadvertent data exposure.
- Data retained beyond its stated purpose: Trigger a deletion workflow immediately.
- Set up auto rules for data age so records are removed right when they hit their expiry date.
- Unencrypted PII in file exports stored in shared drives: Either encrypt those exports or remove the files, lock down access to the folder so only the right people can open it, and turn on encryption in the export process that created those files.
- Cloud storage buckets with overly permissive access containing personal data: Immediately restrict access permissions and initiate a security review to determine whether unauthorised access occurred.
- Orphaned accounts and test data: Delete records associated with test users or decommissioned accounts that have no active data principal relationship and no legitimate retention basis.

For e-commerce businesses where personal data volumes grow rapidly with each transaction cycle, discovery scans should run weekly with daily incremental checks on high-velocity tables. See our DPDP compliance

checklist for e-commerce for a sector-specific operational framework that builds on data discovery as its foundation. How Consiva's Data Discovery Module Works Consiva is purpose-built for DPDP compliance in Indian businesses, and the data discovery module sits at the centre of the platform's architecture. Unlike generic data governance tools designed primarily for GDPR or CCPA, Consiva's scanner is pre-loaded with India-specific PII patterns covering all formats of Aadhaar numbers (with and without spaces or hyphens), PAN card formats for all categories of taxpayers, GSTIN formats for all states and union territories, Indian mobile number prefixes (both pre- and post-number portability), Indian postal PIN codes, all Passport number formats in use, and Voter ID formats used across all 28 states and 8 union territories.

Consiva Data Discovery: Technical Specification Database connectors: Microsoft SQL Server 2014+, MySQL 5.7+, PostgreSQL 12+, Oracle Database 12c+, Amazon Aurora, Amazon RDS, Azure SQL Database, and Google Cloud SQL. Cloud storage connectors: Amazon S3, Azure Blob Storage, Google Cloud Storage, with support for encrypted buckets via KMS/CMK. PII detection engine: 340+ built-in regex patterns covering Indian government IDs, financial info, contact details, and health data fields; a custom pattern builder for your own proprietary identifiers. Scan modes: just the schema for a super quick look, a sample of 500 rows for more depth, or a full statistical analysis — customisable per data source. Incremental scanning: After the initial full scan, Consiva compares table checksums and schema hashes to figure out only what's changed, cutting re-scan times by up to 94% on a stable database. ROPA integration: Classified findings are automatically pushed to the ROPA module as candidate processing activity entries for a data steward to review and confirm. Rights request integration: The discovery index feeds the fulfilment engine for Section 12 erasure and access, making a per-person data location report fast, often within seconds. Security: Database keys and secrets are locked when stored, using AES-256, and data moves over TLS 1.3. Consiva does not keep a copy of your personal data — only metadata such as table name, column name, PII type, and a confidence score. On-premises agent: For organisations that cannot expose database connections to the internet, a lightweight scanner agent deploys within your network perimeter, scans locally, and sends only metadata to the Consiva cloud for analysis. The on-premises scanner agent is particularly relevant for banking, insurance, healthcare, and government-adjacent organisations operating under sector-specific data localisation requirements. The agent is distributed as a Docker container or a system service installer for Windows Server and Linux. See pricing plans including the on-premises agent tier, or contact our team for enterprise deployments requiring custom network topology or air-gapped installation.

The Cost of NOT Doing Data Discovery The DPDP Act 2023 is unambiguous about the financial consequences of non-compliance. Schedule I of the Act sets out a tiered penalty structure with the maximum financial penalty of ₹250 crore per non-compliance event imposable by the Data Protection Board of India. These are not hypothetical maximums — the Board has statutory authority to impose them in proportion to the nature, gravity, and duration of the non-compliance, without requiring proof of harm to any individual data principal.

Non-Compliance Type	Maximum Penalty	Discovery Gap That Triggers It
Failure to implement reasonable security safeguards (Section 8(4))	₹250 crore	Unencrypted

PII in unknown or unmonitored storage locations Failure to notify the Board and data principals of a breach (Section 8(6)) ₹200 crore Cannot notify on a breach of data that was never inventoried Non-compliance with obligations related to children's data (Section 9) ₹200 crore Failure to identify and govern minors' data scattered across systems Failure to fulfil a rights request within the required period (Section 12) ₹50 crore Incomplete erasure because not all data locations were known Other obligations including ROPA accuracy and purpose limitation (Section 6) ₹50 crore Inaccurate ROPA due to undiscovered processing activities Beyond the direct financial penalties, consider the compounding costs: legal representation before the Board (typically ₹5 to 15 crore for complex defended cases), reputational damage from public Board orders (all adjudication orders are required to be published under Section 27(8)), customer attrition following a publicised breach or enforcement action, and the engineering cost of reactive remediation undertaken under regulatory pressure — which is consistently estimated at three to five times the cost of proactive prevention. 💡 A complete initial data discovery scan on Consiva costs a fraction of a single day's legal representation before the Data Protection Board. The return on investment calculation for proactive discovery is not an abstract compliance exercise — it is straightforward financial risk management. Start your free scan today and understand your data landscape before the Board asks you to account for it. The Indian data protection enforcement landscape is moving quickly. The Data Protection Board of India is actively being constituted, the DPDP Rules are approaching finalisation, and enforcement against early non-compliant organisations will serve as precedent for the Board's adjudication approach. The businesses that build their compliance programmes on a solid data discovery foundation now — knowing exactly what personal data they hold, where it lives, who is responsible for it, and how to delete it on demand — will be positioned to respond to any Board inquiry with confidence and evidence. Those that defer discovery until enforcement begins will be scrambling under time pressure, spending far more, and demonstrating exactly the kind of negligence the Board is designed to penalise. Ready to Map Your Personal Data? Consiva's automated data discovery scans your databases and cloud storage in hours, feeds your ROPA automatically, and powers instant Section 12 erasure fulfilment. Start free — no credit card, no lengthy procurement process, results the same day. Get Started Free — Scan Your First Database Today Need guided onboarding for your enterprise? Talk to our team → Frequently Asked Questions What is data discovery in the context of DPDP compliance? + Data discovery is the process of searching through your entire organisation to track down and understand where all personal data is stored — basically tracing the digital footprint of your organisation to figure out where all this personal info is living. It's the key to answering the fundamental question: 'where exactly does personal data hide in our organisation?' Without that knowledge you're left struggling to build a reliable Records of Processing Activities, deal with erasure requests under Section 12 on time, or even keep the Data Protection Board of India off your back. Is data discovery mandatory under the DPDP Act 2023? + The DPDP Act 2023 does not use the phrase "data discovery", but several obligations make it a practical necessity. Section 8(5) requires Data Fiduciaries to maintain accuracy and completeness of personal data. Section

8(7) mandates erasure upon withdrawal of consent or fulfilment of purpose — both of which are impossible without knowing where data resides. The ROPA requirement further demands comprehensive records of all processing activities, which only a systematic discovery scan can reliably produce. What databases and systems can Consiva scan for personal data? + Consiva's data discovery module scans the likes of Microsoft SQL Server, MySQL, PostgreSQL, Oracle Database, and Amazon Aurora, and also checks cloud storage such as AWS S3, Azure Blob and Google Cloud Storage. Plus it looks at shared file systems and API endpoints spewing out JSON, as well as unstructured data within connected systems — that's anything from CSV exports and Excel files to PDFs buried away in your databases. How does data discovery help sort Section 12 erasure requests within 30 days? + DPDP Act Section 12(b) grants data principals the right to erasure of personal data when it is no longer necessary for the purpose it was collected, or when consent is withdrawn. Consiva maintains a continuously updated data map — a record of every table, column, and file that holds a given individual's data. When an erasure request arrives, the platform generates a deletion checklist covering all locations in seconds, enabling your team to execute and document the deletion well within the 30-day window expected under the Act. What are the penalties for DPDP non-compliance and can data discovery reduce risk? + The Digital Personal Data Protection Act 2023 threatens to hit organisations with massive fines up to ₹250 crore if they get it wrong, and the Data Protection Board of India has the power to really make an example of people who aren't playing ball — with graduated sanctions that only get worse depending on how bad things are. But data discovery makes a big difference here because it shows the Board that your organisation has got the "reasonable security safeguards" nailed under Section 8(4), that you know where all your data is, and that you can get on top of data principal requests before they blow up in your face — all of which are big tick boxes for the Board when it comes to making their decisions. What is the difference between active and passive data discovery? + Both active and passive data discovery try to track down personal data within an organisation, but they go about it in very different ways. Active data discovery involves directly connecting to data sources via credentials and running structured queries or file-system traversals to identify personal data in real time. Passive discovery analyses network traffic, query logs, or audit trails to infer what data exists and how it flows between systems — without touching the data stores directly. Consiva primarily uses active discovery for accuracy, supplemented by passive log analysis to identify data that moves through APIs and microservices. How long does an initial data discovery scan take? + For a typical mid-market organisation with 10 to 50 database schemas and under 500 GB of structured data, Consiva's initial scan completes in 2 to 6 hours. Larger enterprises with multiple data warehouses and unstructured file stores may require 24 to 48 hours for the first full scan. Subsequent incremental scans run on a configurable schedule and typically complete within 15 to 30 minutes as they only re-examine changed tables and newly created files. Related Articles ROPA & Records How to Automate Your ROPA for DPDP Compliance 8 min read · Data Privacy E-Commerce The Complete DPDP Compliance Checklist for E-Commerce Businesses 11 min read · Data Privacy SaaS DPDP Compliance for SaaS Companies: What You Need to Know 10

min read · Data Privacy Stay Ahead of DPDP Developments Practical compliance guides, regulatory updates from the Data Protection Board, and Consiva product news — delivered once a week. No spam, unsubscribe anytime. I agree to receive DPDP compliance updates and consent to Consiva processing my email for this purpose. Privacy Policy · Subscribe India's DPDP compliance platform and consent management software — built natively for DPDP 2023, CERT-In, and global privacy frameworks. DPDP 2023 CERT-In GDPR Made in India  ISO 9001 Certified ISO 27001 Certified NASSCOM Member DSCI · DSCI/AM/2026/089 DPIIT Recognised Privacy contact (Rule 9): Saurabh K, Privacy Officer & Grievance Officer saurabhk@swaransoft.com DPDP Knowledge DPDP Act 2023 DPDP Rules 2025 Data Fiduciary Obligations Data Principal Rights & Duties Retention & Erasure Penalties & Enforcement Compliance Blog Privacy Blueprint Industries SaaS & IT D2C & E-commerce BFSI Healthcare EdTech Startups Digital Marketing Agencies Trust & Legal Privacy Policy Terms of Service Cookie Policy Acceptable Use Policy Support Policy Privacy Rights & Grievance Refund & Cancellation Disclaimers & AI Notice Contact & Routing Company About Us Pricing Blog FAQ Contact Sitemap Login → Ask AI About Consiva Get an instant AI-generated overview Open your favorite AI assistant with a ready-made prompt about Consiva ChatGPT Perplexity Claude Google AI Grok © Consiva.ai · A product of Swaran Soft Support Solutions Private Limited CIN: U72200DL2005PTC136405 · GSTIN: 06AAJCS7515G1Z9 Tower A, Unit No. 2, 2nd Floor, The Cityscape, Sector-66, Golf Course Extension Road, Gurugram, Haryana – 122102, India support@consiva.ai · +91 9220313650 · ISO 9001:2015 & ISO/IEC 27001:2022 certified management systems within the scope of providing software development services.

65. DPDP Compliance for SaaS Companies: A Complete Technical Guide | Consiva.ai

Source URL: <https://consiva.ai/blog/dpdp-compliance-saas-companies>

DPDP Compliance for SaaS Companies: A Complete Technical Guide | Consiva.ai ↑ ISO 9001 Certified · ISO 27001 Certified · NASSCOM Member · DSCI Member · DSCI/AM/2026/089 · DPIIT Recognised · Download White Paper Home Platform Platform Overview See the whole operating model — every module, one dashboard Consent & Notice Consent Management Platform Purpose-specific consent with signed, exportable records Cookie Consent Management Scans every cookie and tracker, including ones you didn't add DPDP and GDPR Consent Already run a GDPR CMP? What changes for DPDP Rights & Grievance Data Principal Rights Management Access, correction, erasure, grievance and nomination DSAR Management Software DSAR vs Data Principal request, explained Discovery, Mapping & Records Data Discovery Software Find personal data at rest, column by column Data Mapping Software Purpose-mapped data inventory from discovery findings ROPA Software A Records of Processing Activities register with source attribution Breach & Incident Data Breach Management CERT-In 6-hour and DPDP Rule 7 clocks, tracked independently Governance Processor & DPA Register Vendor DPA status, risk tiers and expiry alerts DPDP Knowledge

DPDP Act 2023 Scope, definitions & key provisions of the law DPDP Rules 2025

Commencement dates & Rule-by-Rule breakdown Data Fiduciary Obligations Notice, consent & lawful processing under §§4–10 Data Principal Rights & Duties Your 4 rights & 5 duties as a data subject Retention & Erasure Rule 8: when to hold data and when to delete it Penalties & Enforcement Full penalty schedule — up to ₹250 Cr per violation FAQ Common questions about DPDP and Consiva Industry SaaS & IT Dual Fiduciary & Processor roles, offshore transfers D2C & E-commerce 2 Cr threshold, purchase consent & 3-year clock BFSI RBI & PMLA retention, defaulter data exemption Healthcare Fourth Schedule carve-out & patient data handling EdTech Rule 10 parental consent & child data protection Startups §17(3) exemptions & lean compliance playbook Digital Marketing Agencies Tag stack liability, Processor vs Fiduciary clarity Blog Pricing Contact Login → Dark Home > Blog > DPDP Compliance for SaaS Companies Technology 10 min read DPDP Compliance for SaaS Companies: A Complete Technical Guide How do SaaS companies comply with India's DPDP Act of 2023 when they handle data from people in India? The rules touch consent, where data must sit, how to handle DSR requests, and how vendor contracts are set up. CA Consiva.ai Research Team May 1, 2026 · Updated May 2026 ~2,200 words On this page Extraterritorial Scope Why SaaS is High-Risk Consent Management Data Residency DSR Workflows in the Cloud Vendor DPAs Multi-Tenant Architecture CERT-In Incident Reporting 8-Step Implementation Roadmap How Consiva Helps FAQ India's Digital Personal Data Protection Act 2023 is a big change in how SaaS teams must work. If a company processes personal data of people in India, the act applies even if the company is based abroad. So, it matters whether your systems are running in Mumbai or in Milwaukee. This is meant for SaaS engineering teams, legal teams, and privacy and compliance owners. It covers the main duties, like the scope of the law, the way consent should be built, data residency steps, and how DSR requests can be handled in cloud setups. It also includes sub processor contract terms, added safeguards for multi tenant setups, and a requirement to report specific incidents to CERT In. Who Is Covered by DPDP 2023? The Extraterritorial Scope The law has a territorial test. In Section 3(a), it applies to processing that happens within India. Section 3(b) adds an extra point: the law can also apply to processing done outside India if that processing links to offering goods or services to people in India. In short, this makes it hard to argue that a foreign company is outside the rules just because it is not incorporated in India. Key Statutory References Section 3 — Territorial and extraterritorial application of the Act Section 4 — Grounds for lawful processing: consent and legitimate uses Section 8 — General obligations of the Data Fiduciary Section 11 — Right of the Data Principal to withdraw consent Section 16 — Additional obligations for Significant Data Fiduciaries Section 19 — Cross-border data transfer restrictions Section 16 introduces the concept of the Significant Data Fiduciary (SDF) — a designation the Central Government can impose on any entity based on volume and sensitivity of data processed, risk to sovereignty or national security, risk to electoral democracy, security of the state, or public order, and the potential impact on the rights of children. An SDF faces elevated obligations: mandatory appointment of an India-resident Data Protection Officer, periodic Data Protection Impact Assessments (DPIAs), algorithm audits, and — critically — data

localisation requirements for categories of data notified by the government. For SaaS companies, the practical implication is immediate: if you have a freemium product popular with Indian consumers, an enterprise tier serving Indian enterprises, or even an API that Indian developers integrate, you are within scope. There is no de minimis exemption based on company size or revenue in India.

Why SaaS Companies Are High-Risk Under DPDP

Traditional enterprises process personal data in bounded, well-understood systems. SaaS companies are quite different in their architecture — which can create a whole heap of DPDP risk: Massive data volumes coming at you fast: SaaS platforms are constantly sucking in behavioural telemetry, usage logs and personal info. You've got a mid-sized B2B SaaS with 50,000 Indian enterprise users — that's tens of millions of personal data events being processed every day from things like authentication logs, audit trails, everything they do in collaboration, and API activity. It's not just a trickle. Data flows across borders, which is half the design of most SaaS platforms — they're routing data across multiple AWS regions or Azure geos to get lower latency, make sure it all keeps running even if things go wrong, and to get some useful analytics. But every time they send Indian personal data across borders they need to make sure it's allowed — it's got to be one of the countries the Central Government says is okay under Section 19.

Multi-tenant shared infrastructure: logical isolation in shared databases introduces risk of accidental cross-tenant exposure during bulk operations, schema migrations, or backup restores.

Complex sub-processor chains: a typical SaaS stack includes a CDN, an error monitoring tool, a product analytics platform, a CRM, an email delivery service, and third-party AI APIs — each potentially processing Indian personal data.

Rapid iteration cycles: continuous deployment means new data fields, new integrations, and new third-party vendors are added faster than traditional legal review processes can track.

Regulatory Risk Signal

The Data Protection Board may charge penalties of as much as ₹250 crore for each instance where security safeguards are not followed. It may also charge up to ₹200 crore for each instance where rules linked to children's data are not met. For a SaaS platform that serves users across countries, one wrong setup in the consent flow can affect a huge number of records at the same time.

Consent Management for SaaS Products

What Constitutes Valid Consent Under DPDP

Section 6 of the DPDP Act sets a high bar for consent validity. Consent must be free, specific, informed, unconditional, and unambiguous — expressed through a clear affirmative action. Pre-ticked boxes, bundling consent with terms of service, or slipping in consent as a condition of service — even if the data is completely unneeded — won't meet this standard. The thing that really matters is that the consent request notice is clearly explained in English or any of the 22 official Indian languages, which the Eighth Schedule of the Constitution lists. That way, users can at least make sense of what they are agreeing to in their own language.

In-Product Consent Banners & Flows

When it comes to B2C SaaS products, you have to get the consent in there somewhere before you start collecting people's personal info for anything that isn't essential. You need to make sure your consent notice lists out clearly: the types of personal data that are being collected, exactly what you're going to use it for, the name and contact details of the company that's responsible for looking after it all, and how people can go back on that consent later. Cookie consent banners

that slap a big 'I agree' box on top of everything — only to be found out later that that included all sorts of tracking that never got discussed — are not going to cut it. You need to ask people for permission every time you want to do something with their data. In technical terms, that means your system for handling consent has got to: Show a consent request page with all the details before you even start loading in the tools you use to track people, like analytics software, ad pixels, and third-party cookies Block any behind-the-scenes requests to other companies (like Segment, Amplitude, Mixpanel, or Intercom) until people agree to that specific use of their data Store a timestamped, versioned consent record in a dedicated audit log — immutable and queryable by user ID Surface an accessible consent withdrawal mechanism within the product, not buried in a support ticketing flow Re-obtain consent if the processing purpose changes materially or if you onboard a new sub-processor for a consented purpose API-Based Consent Signalling for B2B SaaS In B2B scenarios, the SaaS vendor typically processes data under a contract with an enterprise customer (the downstream Data Fiduciary), making the SaaS vendor a Data Processor. However, where the SaaS vendor independently determines the purpose or means of processing — for instance, using customer data to train AI models or to improve its own product analytics — it transitions into a co-fiduciary role for those processing activities.

Scenario DPDP Role Who Controls Purpose? Your Obligations You process customer data on client's instructions only Data Processor Your enterprise client (Data Fiduciary) Written DPA, security safeguards, breach notification to fiduciary, delete on contract end You use customer data to train your AI / improve your product Co-Data Fiduciary You (for that processing activity) Separate consent, full DPDP obligations, DPB registration if SDF-designated B2C SaaS — you collect user data directly Data Fiduciary You Full DPDP obligations: consent, rights, ROPA, DPO (if SDF), breach notification You are a sub-processor of another SaaS Sub-Processor The upstream SaaS (Processor) Contractual obligations to upstream processor; security standards; audit rights B2B SaaS platforms should implement consent signal propagation via API: when a downstream customer informs you that an end-user has withdrawn consent for a specific purpose, your platform must honour that signal within a defined SLA (24 hours is a reasonable technical target) and cease processing for that purpose across all systems, including analytics pipelines, ML training datasets, and recommendation engines. Platforms like Consiva provide webhook-based consent signal ingestion that can automate this propagation across your infrastructure. Start Free on Consiva.ai — No Credit Card Required Map your SaaS data flows, generate DPDP-compliant consent notices in 22 Indian languages, automate DSR workflows, and get audit-ready in days — not months. Get Started Free Data Residency Requirements Under DPDP Section 19 of the DPDP Act authorises the Central Government to restrict cross-border transfers of personal data to countries or territories it deems appropriate, based on factors such as the adequacy of data protection laws in the destination country, treaties with India, and national security considerations. The government is expected to publish an approved transfer list — analogous to the EU's adequacy decisions — along with the Rules under the Act. What the Current Rules Say At the time of writing (August 2026), the DPDP Rules have introduced a whitelist mechanism: personal data of Indian data principals may be transferred to

countries on the approved list without additional safeguards, while transfers to non-listed countries require government approval or the use of standard contractual clauses. Notably, unlike the original Personal Data Protection Bill 2019, the enacted DPDP Act does not impose a blanket data localisation mandate for all personal data — localisation is reserved for categories notified under the Significant Data Fiduciary framework. What Significant Data Fiduciaries Must Do If you are named an SDF, certain types of personal data must be kept in India. This covers things like financial files and health records, plus other sensitive types that are listed as notified. In practice, it means this: Deploying dedicated AWS ap-south-1 (Mumbai) or Azure India Central storage resources for regulated data categories Implementing data classification at the pipeline level — tagging records by sensitivity category at ingestion so that routing policies can enforce residency Configuring geo-restriction policies at the cloud provider level (AWS S3 Bucket Policies with `aws:RequestedRegion` conditions, Azure Policy for allowed locations) Auditing all data replication jobs — cross-region read replicas, disaster recovery snapshots, and data warehouse sync jobs — to ensure regulated categories remain within India boundaries Handling DSRs When Data Lives in Cloud Infrastructure Sections 11 through 14 of the DPDP Act grant data principals the rights to access information, correct inaccurate data, erase personal data, and nominate a nominee. For SaaS companies, the challenge of DSR fulfilment is not legal interpretation — it is engineering: personal data is rarely in a single place. Mapping Your Data Footprint Before you can put in place a Data Subject Request (DSR), you need a complete picture of where all personal data is held — every database table, every object store bucket, every analytics event stream, every machine learning dataset, every backup location, and all the systems using personal data that are connected to the customer or user making the request. For most cloud-based software companies this list will look something like this: Primary transactional database (the main database driving the core business logic of your application — PostgreSQL, MySQL, DynamoDB, etc.) Data warehouse — where you put your data after it's been cleaned up and made easier to analyse (BigQuery, Snowflake, Redshift, etc. — don't forget all the stuff you've stored there like aggregated tables and fancy views) Object storage (S3, GCS, Azure Blob and alike) where you keep structured files, exports, and all the user-uploaded goodies Event streaming systems (the logs and audit trails for those Kafka, Kinesis, Pub/Sub systems) Search and caching layers (Elasticsearch, Redis), not to mention the part where you index all the personal data ML/AI training datasets — if any of your models were trained using customer or user data Backup and disaster recovery snapshots — the ones you're supposed to do so you don't lose everything in an emergency Third-party SaaS integrations — all those other tools and services you've integrated into your app like CRM systems, support desks, email platforms and product analytics Automating Erasure in Cloud Environments Manual erasure across this footprint within the DPDP's "without undue delay" standard is operationally impossible at scale. SaaS teams must build or procure automated DSR orchestration that: (1) receives and authenticates the erasure request, (2) identifies all systems containing records for that data principal, (3) executes deletion or anonymisation across each system in dependency order, (4) handles immutable storage via cryptographic erasure or documented backup expiry scheduling,

and (5) generates an audit trail proving fulfilment. Cloud-native tools like AWS Macie (data discovery), Azure Purview, and GCP's Data Catalog can accelerate the discovery phase, but orchestration requires a purpose-built layer — which is exactly what Consiva's DSR automation module provides.

Vendor and Sub-Processor Data Processing Agreements

The DPDP Act requires Data Fiduciaries to engage Data Processors only under a valid contract that prescribes what the processor may do with the personal data. This is not a formality — the contract is a compliance instrument. Critically, the Data Fiduciary remains liable for any non-compliance by its processors, creating strong incentive to conduct due diligence before onboarding new vendors.

What Your DPAs Must Cover

A DPDP-compliant Data Processing Agreement with each sub-processor should address:

- Scope and purpose limitation:** the processor is authorised to process Indian personal data only for the specific, described purposes — no secondary use, no AI model training unless explicitly permitted.
- Security standards:** save the data using AES-256 encryption, guard the data while it moves by using TLS 1.2 or a later release, put in place access controls, and schedule regular penetration tests.
- Sub-processor limits:** the processor cannot hire any extra sub-processors unless it first gets written permission. Keep a running list of sub-sub-processors that are approved, and update that list when changes are needed.
- Breach notification:** the processor must notify you within 2 hours of discovering a breach involving Indian personal data (shorter than your obligation to CERT-In, to give you time to comply).
- DSR cooperation:** the processor must cooperate with and technically enable DSR fulfilment within defined timelines.
- Audit rights:** you must be able to audit the processor's compliance posture — either through direct audit, third-party assessments, or certified attestations (ISO 27001, SOC 2 Type II).
- Data deletion:** on termination of the agreement, the processor must delete all Indian personal data within a specified period (30 days is standard) and provide written certification of deletion.
- Cross-border transfer controls:** the processor must not transfer Indian personal data to countries outside the approved DPDP list without your explicit authorisation. If you are a SaaS vendor selling to Indian enterprises, your customers will increasingly require you to sign their DPDP-compliant DPA as the Data Processor. Having a well-structured, pre-negotiated DPA template of your own — and being familiar with DPDP obligations — will accelerate your enterprise sales cycle significantly.

Multi-Tenant Architecture: Data Isolation and Erasure

Multi-tenancy is the defining architectural characteristic of most SaaS platforms and presents the most technically nuanced compliance challenge under DPDP. When hundreds of enterprise customers share a database schema, fulfilling the right to erasure for a single data principal requires surgical precision.

Tenant-Aware Data Tagging

Every personal data record must carry a tenant identifier and a data principal identifier at the schema level — not just in application logic. This means adding composite indexes on (tenant_id, user_id) across all tables containing personal data, and enforcing this schema constraint in your data engineering pipelines so that events, logs, and derived tables inherit the tagging automatically.

Erasure Propagation

Challenges

In a multi-tenant SaaS, wiping out data is actually pretty complicated by a few factors that can be managed with some forward thinking:

- Shared aggregations:** if you are working on per-tenant analytics and the numbers come from many users, you cannot just delete

one row. You usually have to redo the totals and counts again from the start. Plan your analytics so it can update results step by step when data changes, or apply differential privacy so results are anonymised for specific user groups. Foreign key nightmares: erasing a user record can cause a chain reaction that breaks foreign key constraints. Take the time to map out all the possible cascades in your data model and document which tables downstream are better off having their records nullified rather than deleted altogether. Audit logs and erasure rights: you may have to hang onto certain data in your audit logs for compliance reasons (think tax or financial regulations), which creates a problem with the erasure rights that data principals are entitled to. Come up with a clear retention policy that draws the line between personal data that has to be erased and anonymised audit records that you're allowed to keep. Backup snapshots: it's just not realistic to expect you'll be able to delete personal data from every single backup you've ever made. Instead, set up a backup retention and expiry policy (say, backups get deleted after 30 days), let the data principal know when they ask for their data to be wiped, and then use crypto-erasure to scramble the data in any backups that are in immutable storage. Cryptographic Erasure For data that's locked away in formats like S3 Glacier or encrypted backup archives — where you can't realistically delete the data itself — the best way to “erase” it is to destroy the encryption key. This means you need to do some extra work upfront to make sure every user's (or data principal's) data is encrypted with a unique key that's stored separately in a key management system (like AWS KMS, Azure Key Vault or GCP Cloud KMS). Once you delete the KMS key, the underlying data is inaccessible — even if it's not actually gone forever from a physical point of view. CERT-In Incident Reporting Obligations for SaaS SaaS companies in India operate under a dual reporting regime: the CERT-In Directions of April 2022 (which remain in force) impose a 6-hour incident reporting window, while the DPDP Act requires notification to the Data Protection Board and affected data principals “without undue delay” following a personal data breach. These obligations interact and must both be satisfied. The three notification targets and their deadlines: Notification Target Deadline Governing Rule What to Include CERT-In Within 6 hours CERT-In Directions 2022 Nature of the incident, systems affected, and a quick note on the harm that has already occurred Data Protection Board (DPB) Within 72 hours DPDP Act, Section 8(6) A summary of the data involved, how many people may be affected, and the steps you are taking to fix it Affected Data Principals Without undue delay DPDP Act, Section 8(6) A simple, clear notice: what data was leaked, the risks, and what you are doing to make things better What Actually Triggers a Reportable Incident When it comes to reporting under CERT-In Directions, SaaS companies have to report a pretty wide range of incidents, including data breaches, personal data being leaked, systems being compromised, ransomware attacks and people getting access to IT infrastructure without permission. The clock starts from the moment you find out about the incident, not when you've finished investigating it or actually managing to shut it down. Building a CERT-In-Ready Incident Response Plan SaaS teams need to be able to get a response plan up and running inside that six-hour window, which is a pretty tight squeeze, even by international standards. What that means in practice is you need: A $\frac{24}{7}$ security operations team (whether you've got one in-house

or you've outsourced it through a SOC) and clear paths of escalation to the person in charge of sending off the CERT-In report Pre-made templates for incident reports that match up with the fields CERT-In wants you to fill in (incident type, systems affected, what you think the scale of the problem is, what you did to contain it) Automated alerts from your SIEM or cloud security tooling that kick off the incident response process as soon as they spot something fishy A parallel notification workflow for the Data Protection Board and affected data principals, with pre-approved communication templates reviewed by legal counsel Log retention for a minimum of 180 days for all ICT systems (including cloud infrastructure logs, VPN logs, and application access logs) as required by CERT-In Directions Synchronisation of logs to Indian time zone (IST) and maintenance of NTP-synchronised timestamps across all systems CERT-In Reporting Timeline for SaaS Incidents A single breach starts six deadlines running in parallel — the CERT-In clock is the tightest. T+0 (Awareness): Internal escalation triggered automatically via SIEM alert T+2h: Sub-processor notifies you per DPA obligation T+6h: CERT-In report filed at incident@cert-in.org.in T+72h: Data Protection Board notification submitted T+7 days: Detailed post-incident report and affected data principal notifications T+30 days: Root cause analysis and remediation evidence submitted to Board Practical 8-Step Implementation Roadmap for SaaS DPDP Compliance

- 1 Conduct a Data Flow Audit and Classification Map every system that ingests, stores, transforms, or transmits personal data of Indian data principals. Classify each data element by sensitivity category (general personal data, children's data, health data, financial data). Document cross-border data flows and sub-processor relationships. This audit is the foundation for all subsequent compliance steps and should be completed in the first four weeks.
- 2 Evaluate Significant Data Fiduciary Exposure Assess whether your volume of Indian personal data, the sensitivity of categories processed, or the nature of your services (children's platforms, health tech, fintech) makes SDF designation likely. Engage outside counsel familiar with the DPDP Rules to obtain a written opinion. If SDF designation is probable, begin planning for an India-resident DPO hire and data localisation architecture immediately.
- 3 Rebuild Your Consent Management Layer Audit existing consent flows against DPDP's requirements: specificity, affirmative action, multilingual notice, withdrawal mechanism. Replace blanket consent with purpose-level consent UI components. Implement a consent audit log with immutable storage. For B2B products, add API endpoints to receive and propagate consent withdrawal signals from downstream Data Fiduciaries.
- 4 Implement Tenant-Aware Personal Data Tagging Add (tenant_id, data_principal_id) composite keys to all personal data tables. Retrofit existing event schemas in your data warehouse and streaming pipelines with these identifiers. This tagging infrastructure is what makes scalable DSR fulfilment and data residency enforcement possible.
- 5 Build or Procure DSR Automation Deploy a DSR intake portal — either custom-built or through a platform like Consiva — that authenticates requestors, classifies requests by type (access, correction, erasure, nomination), routes them to automated fulfilment workflows, tracks SLA compliance, and generates audit-ready evidence. Ensure erasure workflows cover every data store identified in Step 1, including backups (via documented expiry policy) and sub-processors (via DPA-mandated DSR cooperation).
- 6 Audit and Update All Sub-

Processor Agreements Review every vendor contract against the DPDP DPA requirements outlined in this guide. Issue updated DPAs to all sub-processors and set a deadline for countersignature. Terminate or replace any vendor that cannot or will not execute a compliant DPA. Build a sub-processor register and a process for evaluating new vendors before onboarding.

7 Implement Data Residency Controls in Cloud Infrastructure Configure cloud IAM policies, S3 bucket policies, and Azure/GCP equivalents to enforce data residency for regulated categories. Enable data classification labels in your cloud provider's governance tooling (AWS Macie, Microsoft Purview, GCP Data Catalog). Audit all cross-region replication jobs and disable or restrict those that move regulated personal data outside India or approved territories.

8 Operationalise Incident Response for CERT-In and DPDP Board Reporting Document and test your incident response runbook against the 6-hour CERT-In reporting requirement. Choose one CERT-In reporting person by name, available any hour, day or night. Set up your SIEM so it triggers an alert workflow and reaches the on-call security engineer within a few minutes. Draft the incident notice templates for CERT-In, the Data Protection Board, and affected people, and send them for legal review before you use them. Run a tabletop drill that simulates a breach at least once every quarter.

How Consiva's SaaS-Native Compliance Platform Helps Consiva was built specifically for the DPDP compliance needs of SaaS companies operating in or serving India. Unlike generic GRC tools adapted from EU GDPR playbooks, Consiva's platform reflects the specific requirements of the DPDP Act and CERT-In Directions from the ground up.

Data Discovery and Classification Consiva's automated scanner connects to your cloud environments (AWS, Azure, GCP) via read-only IAM roles and discovers personal data across databases, object stores, and event streams. It classifies data by DPDP category and generates a live, queryable data map — updated continuously as your schema evolves. This replaces the manual spreadsheet-based data inventory that becomes stale within weeks of creation.

Consent Management SDK Drop our React/Vue/vanilla JS consent SDK into your product to render purpose-level consent banners compliant with DPDP's language requirements across all 22 Scheduled languages. The SDK handles consent signal storage, audit logging, and withdrawal propagation via webhook to your backend — so your engineering team does not need to build this infrastructure from scratch.

DSR Orchestration Consiva's DSR module provides a white-label intake portal for your users, automated identity verification, request classification, and pre-built fulfilment connectors for major cloud databases, data warehouses, and popular third-party SaaS platforms. Every fulfilment step generates an evidence record, giving you an audit trail for Board investigations or customer inquiries.

Sub-Processor Management and DPA Generation Keep an eye on your sub-processor log inside Consiva. Watch the DPA progress as it runs. Create DPDP-ready DPA forms for each vendor link. You will get email or in-app nudges when a DPA is not signed yet, when it is close to expiring, or if a vendor's security proof expires.

Incident Response Playbooks Consiva has an incident response area. It includes CERT-In report templates with your organisation's info already filled in. You follow a clear process that runs for about six hours, showing you the steps in order. It also sends urgent alerts to the right team fast — for each situation, it can use PagerDuty, Opsgenie, or Slack. After the incident ends, the tool

makes the files you need for the Data Protection Board forms. Ready to Make Your SaaS DPDP-Compliant? Join hundreds of SaaS companies using Consiva to automate DPDP compliance — from consent management to DSR fulfilment to incident reporting. Get started in minutes with our free tier. Start Free — No Credit Card

Frequently Asked Questions

Does the DPDP 2023 apply to foreign SaaS companies serving Indian users? + Yes, it does. And it's pretty straightforward — Section 3 of the Digital Personal Data Protection Act 2023 specifically says that any entity processing data on Indian users is subject to the Act, regardless of where they are based or where that data is stored. So a US-based SaaS company selling to Indian businesses or users here straight away falls under this rule. There's no magic number of customers or a minimum amount of money made which gets them out of it either. What is a Significant Data Fiduciary and how will that impact a SaaS business?

 + The Government can designate any data handler as a Significant Data Fiduciary (SDF) if they process a lot of sensitive data, pose a risk to national security or the general order. And that comes with a whole extra set of rules. These SDFs will need to have a Data Protection Officer here in India, do data impact assessments regularly, have their algorithms audited and in some cases have to store data locally here. And some companies, especially those in health, finance, ed-tech and platforms that serve kids, are at higher risk of being designated as an SDF. How should a multi-tenant SaaS platform manage the right to erasure? + Multi-tenant SaaS platforms need to tag each piece of data as it comes in with the right person it belongs to, and when someone asks to have that data erased, that has to be done across the board — in storage, backup, analytics and even any cached data. This means they have to have systems in place to track this data and make sure it gets deleted everywhere it's stored. Cryptographic erasure — where the tenant-specific encryption key is destroyed — is an accepted technical approach for data in immutable storage such as object stores or data warehouses, provided the approach is documented and communicated to the data principal at the time of their request. What are the CERT-In breach reporting timelines for SaaS companies? + Under the CERT-In Directions of 2022, SaaS companies must report any personal data breach to CERT-In within six hours of becoming aware of the incident. The DPDP Act separately requires notification to the Data Protection Board and affected data principals without undue delay. In reality, SaaS teams should aim to hit these key milestones: get an initial CERT-In report on the table within 6 hours, inform the Board about what's happened within a 72-hour window, and send individual data principal notices within a week. To give yourself any shot at responding in time, you should also make sure your sub-processors are on top of things and can get a word in about a breach within a couple of hours. That way you'll have the time you need to get the necessary paperwork done. Can Consiva's platform integrate with cloud-native infrastructure to automate DSR fulfilment? + Yes. Consiva provides pre-built connectors for AWS, Azure, and GCP that scan tagged datasets, execute deletion or portability jobs, and generate audit-ready evidence logs — all from a single orchestration dashboard. The platform also includes a no-code DSR intake portal that you can embed in your product or connect via API, so end-users can submit requests directly without requiring engineering effort per request. Do SaaS sub-processors need separate Data

Processing Agreements under DPDP? + Yes. The DPDP Act calls for a contract to govern the relationship between your SaaS operation and any third-party processor you use — and that includes analytics vendors, payment gateways, the companies that provide your content delivery networks, and the teams behind the AI APIs your product relies on. If you've got sub-processors in the mix, you need to have DPAs in place that outline in good detail the ways in which they're supposed to be processing your users' data: the reasons they're allowed to tap into it, the level of security they must ensure, how they'll let you know if there's a breach, and how long it'll take them to wipe any data they've got. The Data Fiduciary itself is still on the hook for anything its sub-processors mess up — so doing your homework on the vendors you work with, and making sure you've got a handle on the contractual obligations and controls in place, is a crucial part of keeping risk at bay. Related Articles E-Commerce DPDP Compliance Checklist for E-Commerce Platforms Selling in India 8 min read · Consiva.ai Data Management Data Discovery for DPDP Compliance: Finding Personal Data Across Your Stack 7 min read · Consiva.ai AI & Automation AI-Powered DPDP Compliance Automation: A Complete Guide 10 min read · Consiva.ai Stay Ahead of DPDP Developments Get weekly updates on DPDP Rules notifications, Data Protection Board guidance, and practical compliance tips — delivered to your inbox. I agree to receive DPDP compliance updates and consent to Consiva processing my email for this purpose. Privacy Policy · Subscribe India's DPDP compliance platform and consent management software — built natively for DPDP 2023, CERT-In, and global privacy frameworks. DPDP 2023 CERT-In GDPR Made in India  ISO 9001 Certified ISO 27001 Certified NASSCOM Member DSCI · DSCI/AM/2026/089 DPIIT Recognised Privacy contact (Rule 9): Saurabh K, Privacy Officer & Grievance Officer saurabhk@swaransoft.com DPDP Knowledge DPDP Act 2023 DPDP Rules 2025 Data Fiduciary Obligations Data Principal Rights & Duties Retention & Erasure Penalties & Enforcement Compliance Blog Privacy Blueprint Industries SaaS & IT D2C & E-commerce BFSI Healthcare EdTech Startups Digital Marketing Agencies Trust & Legal Privacy Policy Terms of Service Cookie Policy Acceptable Use Policy Support Policy Privacy Rights & Grievance Refund & Cancellation Disclaimers & AI Notice Contact & Routing Company About Us Pricing Blog FAQ Contact Sitemap Login → Ask AI About Consiva Get an instant AI-generated overview Open your favorite AI assistant with a ready-made prompt about Consiva ChatGPT Perplexity Claude Google AI Grok © Consiva.ai · A product of Swaran Soft Support Solutions Private Limited CIN: U72200DL2005PTC136405 · GSTIN: 06AAJCS7515G1Z9 Tower A, Unit No. 2, 2nd Floor, The Cityscape, Sector-66, Golf Course Extension Road, Gurugram, Haryana – 122102, India support@consiva.ai · +91 9220313650 · ISO 9001:2015 & ISO/IEC 27001:2022 certified management systems within the scope of providing software development services.

66. How to Automate ROPA Generation for DPDP Compliance | Consiva.ai

Source URL: <https://consiva.ai/blog/automate-ropa-dpdp-compliance>

How to Automate ROPA Generation for DPDP Compliance | Consiva.ai † ISO 9001 Certified · ISO 27001 Certified · NASSCOM Member · DSCI Member · DSCI/AM/2026/089 · DPIIT Recognised · Download White Paper Home Platform Platform Overview See the whole operating model — every module, one dashboard Consent & Notice Consent Management Platform Purpose-specific consent with signed, exportable records Cookie Consent Management Scans every cookie and tracker, including ones you didn't add DPDP and GDPR Consent Already run a GDPR CMP? What changes for DPDP Rights & Grievance Data Principal Rights Management Access, correction, erasure, grievance and nomination DSAR Management Software DSAR vs Data Principal request, explained Discovery, Mapping & Records Data Discovery Software Find personal data at rest, column by column Data Mapping Software Purpose-mapped data inventory from discovery findings ROPA Software A Records of Processing Activities register with source attribution Breach & Incident Data Breach Management CERT-In 6-hour and DPDP Rule 7 clocks, tracked independently Governance Processor & DPA Register Vendor DPA status, risk tiers and expiry alerts DPDP Knowledge DPDP Act 2023 Scope, definitions & key provisions of the law DPDP Rules 2025 Commencement dates & Rule-by-Rule breakdown Data Fiduciary Obligations Notice, consent & lawful processing under §§4–10 Data Principal Rights & Duties Your 4 rights & 5 duties as a data subject Retention & Erasure Rule 8: when to hold data and when to delete it Penalties & Enforcement Full penalty schedule — up to ₹250 Cr per violation FAQ Common questions about DPDP and Consiva Industry SaaS & IT Dual Fiduciary & Processor roles, offshore transfers D2C & E-commerce 2 Cr threshold, purchase consent & 3-year clock BFSI RBI & PMLA retention, defaulter data exemption Healthcare Fourth Schedule carve-out & patient data handling EdTech Rule 10 parental consent & child data protection Startups §17(3) exemptions & lean compliance playbook Digital Marketing Agencies Tag stack liability, Processor vs Fiduciary clarity Blog Pricing Contact Login → Dark DPDP Compliance 9 min read How to Automate ROPA Generation for DPDP Compliance Records of Processing Activities are the backbone of any data protection programme. Under India's DPDP Act 2023, keeping them accurate, complete, and audit-ready is non-negotiable — and automation is the only practical way to do it at scale. C Consiva.ai Editorial Team 15 April 2026 · Updated regularly Home > Blog > Automate ROPA for DPDP On this page What Is ROPA? DPDP vs GDPR Requirements What to Document Manual vs Automated ROPA Data Discovery & ROPA ROPA by Department Maintaining ROPA Over Time Audit Readiness How Consiva Automates ROPA Step-by-Step Guide Mistakes to Avoid FAQ What Is ROPA and Why Does It Matter Under DPDP 2023? A Record of Processing Activities (ROPA) is a structured inventory of every way your organisation collects, uses, stores, shares, or deletes personal data. Think of it as the master map of your data ecosystem — who generates what data, for what reason, how long it lives, and who it travels to. Under India's Digital Personal Data Protection Act 2023 (DPDP Act) , maintaining accurate records of processing activities is not optional. Section 10 of the Act places obligations on significant data fiduciaries (SDFs) — entities the central government notifies based on volume of data processed, sensitivity, national security implications, and risk to data principals. The draft DPDP

Rules extend record-keeping expectations to all data fiduciaries that process personal data at meaningful scale. Beyond regulatory compliance, a well-maintained ROPA delivers real operational value. It helps your legal, security, and product teams understand exactly what data exists in your systems — which is the first step toward building privacy by design, fulfilling data principal rights requests (access, correction, erasure under Section 12 and Section 13), and minimising breach exposure. When a breach occurs, a complete ROPA tells you within minutes exactly which individuals are at risk and what data was exposed. ⚠️ Penalty exposure: The DPDP Act (Section 33) authorises the Data Protection Board to impose penalties of up to ₹250 crore on significant data fiduciaries that fail to observe their obligations. Inadequate ROPA is evidence of systemic non-compliance and can compound penalties across multiple violations in a single inquiry.

DPDP 2023 vs GDPR Article 30: A Practical Comparison

India's DPDP Act	Europe's GDPR
Who must maintain ROPA	All controllers & processors (with SME threshold)
All data fiduciaries; enhanced obligations for SDFs	All data fiduciaries
Legal basis documentation	Mandatory (Article 6 lawful basis)
Consent or legitimate use under Section 4	Consent or legitimate use
Data transfers	Must list third-country transfer safeguards
Restricted transfers; data localisation for notified categories (Section 16)	Restricted transfers; data localisation for notified categories
DPO / contact details	DPO contact required in ROPA
Data Protection Officer details	mandatory for SDFs
Retention periods	Must be documented
Must delete data when purpose fulfilled or consent withdrawn (Section 8)	Must delete data when purpose fulfilled or consent withdrawn
Enforcement body	National supervisory authorities (e.g. ICO, CNIL)
Data Protection Board of India	Children's data Article 8 parental consent
Verifiable parental consent mandatory; no tracking or behavioural profiling (Section 9)	The key DPDP-specific nuance is purpose limitation and erasure . Section 8(7) requires that personal data be erased once the purpose for which it was collected is no longer being served — or upon the data principal withdrawing consent. Your ROPA must therefore capture not just what data you hold but the active purpose that justifies holding it, so you can trigger deletion workflows the moment that purpose lapses.

What Must Be Documented in Your ROPA

A complete ROPA entry for each processing activity should capture the following fields. These align with both DPDP obligations and international best practice from ISO 27701 and the NIST Privacy Framework.

Department	Data Category	Purpose	Legal Basis	Retention Period	Third-Party Recipients
HR	Employee PII (name, PAN, Aadhaar, salary, bank details, medical certificates)	Payroll processing; statutory compliance (PF, ESIC, TDS filing)	Contractual obligation; legal requirement (Income Tax Act, EPF Act)	7 years post-employment	Payroll processor (ADP / Razorpay); EPFO; Income Tax Department; ESIC
Marketing	Customer email, mobile, browsing behaviour, purchase history, location data	Personalised campaigns; re-targeting; product recommendations; A/B testing	Explicit consent (DPDP Section 6)	36 months or until consent withdrawn	Mailchimp; Meta Ads; Google Ads; Segment; MoEngage
Sales / CRM	Prospect name, company, email, deal value, call recordings	Pipeline management; lead nurturing; sales forecasting	Legitimate use / consent	Active + 24 months post-churn	Salesforce; Zoom (call

recordings); LinkedIn Sales Navigator; Gong IT / Security Access logs, VPN usage, device IDs, IP addresses, authentication records Incident detection; audit trail; CERT-In log retention compliance Legal obligation; legitimate use 180 days minimum (CERT-In Directions 2022) SIEM vendor (Splunk / Sumo Logic); cloud provider audit logs (AWS CloudTrail) Finance Invoice data, bank account numbers, GST numbers, payment records, PAN Accounts payable/receivable; GST compliance; statutory audit preparation Legal obligation (GST Act; Companies Act 2013) 8 years (Companies Act 2013, Section 128) Payment gateway (Razorpay / Stripe); CA firm; GST portal; MCA Additional Fields for a Production-Grade ROPA Beyond the core six columns above, a comprehensive ROPA typically captures: Data source: Where does data enter your systems — web form, API, third-party data purchase, or employee self-service portal? Cross-border transfers: Is personal data transmitted outside India? If so, to which countries, under what safeguards per DPDP Section 16? Security measures: Encryption standard applied (AES-256 at rest, TLS 1.3 in transit), access controls (RBAC, MFA), pseudonymisation status. Data principal rights mechanism: How are access, correction, and erasure requests fulfilled for this specific dataset? Last reviewed date and reviewer: When was this entry last validated by a human data owner? Processing system reference: Which database, SaaS platform, or file store physically holds the data — for linking to data discovery scan results. Start Building Your ROPA Automatically Consiva.ai scans your connected databases and SaaS tools, classifies personal data, and generates a complete, audit-ready ROPA — no spreadsheets, no manual interviews, no guesswork. Start Free on Consiva.ai — No Credit Card Required Manual ROPA vs Automated ROPA: Honest Pros and Cons Most organisations begin their ROPA journey with a spreadsheet. It is familiar, free, and requires no procurement approval. But as your organisation scales — more systems, more vendors, more data types — the spreadsheet model breaks down in predictable and dangerous ways. Risks of Spreadsheet-Based ROPA Version drift: Different departments maintain separate copies; by the time they are consolidated into a master file, the enterprise view is already outdated and internally inconsistent. No linkage to live systems: A spreadsheet records what someone believed was true at the time of writing. It cannot detect a newly deployed microservice that started logging user email addresses last Tuesday. Manual interview bottleneck: Populating ROPA correctly requires interviewing data owners across HR, IT, Marketing, Finance, and Operations. This process typically takes four to twelve weeks for a mid-sized organisation and must be repeated in full every time something changes. No audit trail: A spreadsheet does not record who changed which entry, when, or on whose authority — fatally weakening its credibility as evidence before the Data Protection Board. Deletion management is practically impossible: The DPDP Act requires deletion when processing purpose lapses (Section 8). Tracking this across hundreds of datasets in a spreadsheet — and actually triggering the deletion — is not feasible without automation. Benefits of Automated ROPA Continuously reflects the actual state of your data landscape, not a snapshot from six months ago captured under time pressure. Creates an immutable, time-stamped audit log of every change, with the identity of the responsible party recorded. Integrates deletion triggers — when a purpose record is marked expired, it can initiate a workflow to purge or anonymise the

underlying data and log the evidence of completion. Reduces the operational cost of compliance from weeks of interviews per cycle to a continuous background process requiring human review only for exceptions. Surfaces undocumented processing automatically — when the scanner detects a database table containing email addresses that has no corresponding ROPA entry, it flags it immediately for remediation. Key Insight The DPDP Act's deletion obligation under Section 8(7) makes automated ROPA not just convenient but practically necessary. Only an automated system can reliably identify when a processing purpose has lapsed across thousands of records spanning dozens of systems simultaneously — and initiate the appropriate deletion workflow with a verifiable evidence trail.

How Data Discovery Feeds Into ROPA Generation

You cannot document what you have not found. Data discovery is the technical process of scanning your systems — relational databases, object stores, SaaS APIs, file systems, data warehouses — to identify where personal data lives, what form it takes, and how it flows between systems. A data discovery tool classifies columns and fields using pattern matching, machine learning, and schema analysis. It flags fields that match patterns like PAN card formats (AAAAA9999A), email address structures, Indian mobile number patterns, Aadhaar digit patterns, IP addresses, and financial account identifiers. These classifications map directly to ROPA data categories defined under the DPDP Act. The relationship between discovery and ROPA is not one-directional. When ROPA is generated from discovery output, subsequent discovery scans can diff the results — identifying new tables that appeared since the last scan, fields whose data content changed (e.g., a column that now contains email addresses that previously held only product reference IDs), or data that has migrated to a new system without a corresponding ROPA update. These diffs trigger ROPA update workflows and assign them to the appropriate data owners automatically. This continuous loop between discovery and ROPA documentation is what separates a compliance programme that holds up under regulatory scrutiny from one that merely looks good on paper. Explore this in depth in our companion guide on data discovery for DPDP compliance.

ROPA by Department: What Each Team Needs to Declare

Personal data does not sit in one place or flow through a single system. Every department in your organisation is, in effect, a data fiduciary in miniature — it makes decisions about what data to collect, why, and for how long. A complete ROPA programme assigns a named data owner in each department who is accountable for the accuracy of their ROPA entries.

-  **HR & People Operations** Employee PII (Aadhaar, PAN, bank details, medical records, disciplinary notes, performance ratings), candidate data from applicant tracking systems, background verification reports, leave and attendance records, and salary revision history. Retention is governed by labour law (EPF Act, Gratuity Act, Income Tax Act — typically 7 years). Cross-border transfers arise when using global HRMS platforms such as Workday or SAP SuccessFactors hosted outside India.
-  **Marketing** Customer email lists, behavioural analytics data (GA4, Mixpanel, Amplitude), advertising pixel identifiers, cookie-sourced device IDs, campaign engagement scores, and lead magnet submission data. Under DPDP, consent is typically the only valid legal basis. ROPA must enumerate every ad platform, customer data platform (CDP), and marketing automation vendor receiving this data, including sub-processors.

 **Sales & CRM** Prospect and customer contact data, deal stage and value, call recordings (Gong, Zoom), email conversation threads, and company firmographic data. CRM systems (Salesforce, HubSpot, Zoho) are significant personal data repositories. Sales ROPA must note whether call recordings capture third-party individuals — for example, customer-side participants — who did not provide explicit consent for recording.

 **IT & Security** System access logs, authentication records, VPN connection metadata, device fingerprints, CCTV footage (if digitised and stored), and network traffic data. CERT-In Directions (April 2022) mandate retention of logs for a minimum of 180 days. The DPDP Act requires security measures proportionate to the sensitivity of data processed. These two obligations — mandatory retention and purpose-limited retention — must be explicitly reconciled in your ROPA entries.

 **Finance & Accounts** Customer billing records, payment card data (PCI-DSS scope), GST filing data, vendor bank account details, salary disbursement records, and TDS certificates. Long statutory retention periods (7–8 years under the Companies Act 2013, Section 128) create large legacy data pools that require periodic review to confirm the continued lawfulness of retention.

 **Product & Engineering** Product telemetry, crash reports, feature usage events, A/B test assignments, user-generated content, and session replay data. Engineering teams frequently add new event tracking without a prior privacy review. Integrating ROPA into your product feature launch checklist ensures that new data collection is documented before code ships to production — not after a regulator asks about it. Maintaining ROPA Through Organisational Changes A ROPA that was accurate six months ago may be dangerously incomplete today. Organisations change constantly — new vendors are onboarded, products are launched, databases are migrated, and teams are restructured. Each of these events can introduce personal data flows that are not captured in an existing ROPA, creating silent compliance gaps.

Trigger Events That Require Immediate ROPA Updates

New vendor onboarding: Any third-party vendor that will process personal data on your behalf is a data processor under DPDP. Their details — legal name, registered country, data categories processed, the processing purpose they serve, and the Data Processing Agreement reference number — must be added to the relevant ROPA entries before processing begins.

New product features: A feature that collects a new data field — for example, adding biometric authentication, requesting location access, or collecting age verification data — requires a new or updated ROPA entry to be created and approved before the feature is released to users.

System migrations: Moving personal data from on-premise databases to cloud storage changes the data location, the security posture, and potentially the jurisdiction of storage. ROPA entries must be updated to reflect the new system reference, new security measures, and any new cross-border transfer implications immediately post-migration.

Mergers and acquisitions: Acquiring another company means inheriting their data flows. A privacy due diligence exercise during M&A should produce a ROPA delta document — a structured list of all processing activities in the target entity — which is then merged into your master ROPA post-completion.

Regulatory changes: When new data categories are defined as sensitive under amended DPDP Rules, existing ROPA entries for those categories may need updated consent mechanisms, security measures, or retention periods to remain compliant.

Best Practice Embed

a ROPA review gate into your vendor procurement process and product launch checklist. No vendor contract should be signed, and no product feature collecting personal data should be deployed to production, without a corresponding ROPA entry being created or updated and approved by the data owner. This transforms ROPA from a retrospective documentation exercise into a proactive privacy control that prevents undocumented processing from ever occurring.

Preparing Your ROPA for a DPDP Regulatory Audit

The Data Protection Board of India (DPBI) can initiate inquiries on its own motion or upon a complaint from a data principal. During an investigation, one of the first documents inspectors are likely to request is your ROPA — it immediately signals whether your organisation has a systematic, documented approach to compliance or is operating without adequate controls.

What Inspectors Look For

Completeness:

Does the ROPA cover all significant processing activities across all departments? Large categories are often missing in first-generation ROPAs — employee data, analytics data, IT security logs, and legacy customer databases are common omissions.

Accuracy:

Are the third-party recipients still accurate? Are the retention periods stated consistent with what is actually applied in the underlying databases? Inspectors may cross-reference your ROPA against sample database queries.

Currency:

When was each entry last reviewed, and by whom? A ROPA that has not been updated in 18 months signals neglect of ongoing compliance obligations.

Consent linkage:

For processing activities relying on consent under DPDP Section 6, can you demonstrate that a valid, specific, and informed consent was obtained for each data principal whose data is processed under that entry? Consent records should be traceable from the ROPA entry to individual consent logs.

Deletion evidence:

For purposes that have lapsed — retention periods expired, consent withdrawn — is there a verifiable record that data was deleted or anonymised in accordance with Section 8(7)? An inspector will ask for evidence of deletion, not just a documented policy.

Cross-border transfer documentation:

If personal data is transferred outside India, are the receiving countries, transfer mechanisms, and any applicable contractual clauses documented and lawful under Section 16?

Automated ROPA addresses each of these inspection criteria by maintaining a live, versioned, evidence-linked record. If you are preparing for a potential audit today, the most effective first step is to engage a compliance assessment to identify the gaps between your current records and the standard that inspectors will apply.

How Consiva Auto-Generates ROPA by Scanning Connected Systems

Consiva.ai is built on the principle that compliance documentation should be a by-product of your data operations — not a separate, manually intensive exercise that competes with business priorities. Here is how the platform generates and continuously maintains your ROPA.

Data Source Connectors

Consiva connects to your data sources via read-only, encrypted connectors requiring no write access to your systems. Supported integrations include relational databases (MySQL, PostgreSQL, Microsoft SQL Server, Oracle), cloud-hosted databases (Amazon RDS, Google Cloud SQL, Azure SQL Database), analytical warehouses (BigQuery, Snowflake, Redshift, Databricks), SaaS platforms via OAuth 2.0 (Salesforce, HubSpot, Workday, Zoho CRM, Freshdesk), and cloud file stores (Amazon S3, Google Cloud Storage, Azure Blob Storage). All credentials are stored with AES-256 encryption in a secrets vault isolated from the

application layer. Automated Personal Data Classification Consiva's classification engine analyses column metadata, data types, and statistically sampled values — never requiring a full-table read — to identify personal data fields. It uses a taxonomy aligned to DPDP-defined categories: name and contact information, financial data, biometric identifiers, health and medical data, government identity document numbers (PAN, Aadhaar, passport), and children's personal data. Each classified field receives a confidence score; low-confidence classifications surface as human review tasks rather than being auto-approved. Data Flow Mapping By analysing query logs, API call histories, and ETL pipeline configurations where accessible, Consiva maps how personal data moves between systems within and beyond your organisation. It can identify when data from your CRM is being regularly exported to a marketing automation platform, or when HR records are replicated nightly to a BI dashboard accessible by managers across multiple countries — flows that are often completely undocumented in traditional ROPA processes built on departmental interviews alone. ROPA Draft Generation and Owner Approval Using classified fields and mapped flows, Consiva generates a structured ROPA with pre-populated entries for each identifiable processing activity. Department assignment is inferred from the data source context (data in your HRMS maps to HR; data in your e-commerce database maps to Sales or Marketing). Data owners receive in-app and email notifications to review their department's draft entries, confirm or correct the pre-populated fields, add vendor relationships not yet captured via connectors, and formally approve the record. Each approval is time-stamped and signed to the approver's identity. Continuous Monitoring and Change Alerts Consiva re-scans connected sources on a configurable schedule — daily, weekly, or near-real-time via database change data capture (CDC) webhooks. Any schema change, new table, new data category detection, or new API integration that involves personal data triggers an alert and creates a ROPA update task. This ensures your ROPA is never more than one scan cycle behind the actual state of your data infrastructure. See our pricing page to understand which plan includes real-time monitoring.

Step-by-Step Guide to Building Your First ROPA with Consiva

- 1 Connect Your Data Sources** Log in to your Consiva account and navigate to Settings → Integrations. Add your databases and SaaS platforms using read-only credentials or OAuth 2.0 consent. Start with your highest-risk systems: your CRM, HRMS, customer database, and marketing automation platform. Consiva validates connectivity and confirms read-only access before proceeding.
- 2 Run the Initial Discovery Scan** Trigger a discovery scan from the Data Discovery dashboard. Consiva scans metadata, schema structures, and sampled data across all connected sources. For a typical organisation with 10–20 data sources, this takes 15–45 minutes. Review the classification results in the Personal Data Map view. Adjust confidence thresholds and correct any misidentified fields before proceeding to ROPA generation.
- 3 Review Auto-Generated ROPA Entries** Navigate to the ROPA module. Consiva will have pre-populated entries based on discovery results, grouping related data fields into logical processing activities by department and system. Each entry shows the data source, classified data categories, and inferred processing context. Review each entry, correct any misclassifications, and add fields requiring human input: the specific processing purpose, the legal basis under DPDP, and vendor

relationships not yet connected to Consiva. 4 Assign Data Owners and Send for Departmental Review Each ROPA entry should be assigned to a named data owner — the HR Manager for employee processing activities, the Marketing Director for campaign data, the CTO for IT logs. Consiva sends email notifications with a direct review link. Data owners review their department's entries in a simplified interface, confirm retention periods, add vendor relationships not captured automatically, and submit their approval. Each approval is logged with timestamp and identity. 5 Configure Retention Policies and Deletion Workflows For each ROPA entry, set the retention period and link it to the processing purpose. When a retention period expires or a purpose is marked complete, Consiva can send automated deletion reminders to data owners, trigger webhook integrations with your data management tools, or log a deletion confirmation record for audit purposes. This directly satisfies the Section 8(7) erasure obligation under the DPDP Act. 6 Export, Schedule Reviews, and Monitor Continuously Download your completed ROPA as a structured PDF, CSV, or JSON export at any time for regulatory submissions, board reporting, or external audits. Configure continuous monitoring so the ROPA updates automatically as your data landscape evolves. Set up quarterly review reminders so human data owners validate their entries even in periods of lower change activity. Your ROPA is now a live compliance asset, not a static document. 💡 Time to first ROPA: Most Consiva customers complete a reviewed, approved ROPA within 5–10 business days of onboarding, compared to the 6–12 weeks typically required by manual interview-based approaches. Register free to start your first scan today. Key Mistakes to Avoid in ROPA Management Treating ROPA as a one-time project: Completing ROPA once and never updating it is the single most common compliance failure. The DPDP Act's deletion and purpose-limitation obligations require ROPA to be continuously accurate. Build scheduled review cycles and automated monitoring from day one. Documenting systems rather than processing activities: ROPA should record what you do with data (e.g., "employee payroll processing") not merely which system holds it (e.g., "SAP"). One system may support multiple distinct processing activities with different purposes, legal bases, retention periods, and recipients — each requires a separate ROPA entry. Ignoring shadow IT: Departments routinely use SaaS tools that IT and legal are unaware of — wellness apps that collect employee biometric data, sales reps sharing leads via WhatsApp, designers storing client photos in personal cloud drives. A data discovery scan surfaces these invisible flows; a questionnaire-only approach does not. Listing recipients without Data Processing Agreements: Every third party receiving personal data should have a signed DPA referencing your obligations as a data fiduciary and their obligations as a data processor. ROPA entries should reference the DPA document number. A recipient listed in ROPA without a corresponding DPA is an immediate remediation priority before any audit. Documenting retention without enforcement: Stating a two-year retention period in ROPA means nothing if data sits in your production database indefinitely. Retention policies must be enforced by actual deletion workflows. If you cannot demonstrate that data was deleted at the recorded date, the ROPA entry is worse than useless — it proves you documented a policy you did not follow. No version history: Regulators investigating an incident want to know not just what your ROPA says today but what it said at the time the

incident occurred. Maintain versioned history with timestamps, change authors, and the specific fields modified. Consiva maintains this automatically; manual spreadsheets typically do not.

Excluding consent records from ROPA: Under DPDP, consent is the primary lawful basis for most B2C processing. Your ROPA entries for consent-based activities should link to the consent management system that holds the individual consent records, so inspectors can trace from the ROPA to actual consent evidence in a single audit thread.

Ready to Automate Your ROPA? Join compliance teams across India using Consiva to stay ahead of DPDP obligations — from automated data discovery to real-time ROPA maintenance, consent management, and breach reporting in one integrated platform. Get Started Free — No Credit Card Required

Frequently Asked Questions

Is ROPA mandatory under India's DPDP Act 2023? + Yes. While the DPDP Act 2023 does not use the term 'ROPA' verbatim, Section 10 and the draft DPDP Rules require significant data fiduciaries to maintain records of their processing activities. The Data Protection Board can demand these records during inquiries. Organisations that cannot produce accurate records face penalties of up to ₹250 crore. Even entities that have not yet been notified as SDFs should maintain ROPA as a foundational compliance practice, since SDF status can be assigned as the regulatory framework matures.

What is the difference between ROPA under GDPR and ROPA under DPDP 2023? + GDPR Article 30 mandates ROPA for all controllers processing personal data at scale, with a small enterprise exemption. India's DPDP Act focuses enhanced obligations on 'significant data fiduciaries' notified by the central government, but all data fiduciaries are expected to demonstrate lawful processing. GDPR ROPA must include the specific legal basis (one of six under Article 6) and the supervisory authority contact; DPDP ROPA emphasises consent records with Notice compliance, purpose limitation, and data localisation requirements for certain sensitive categories under Section 16. Children's data obligations are also more explicit under DPDP Section 9, requiring verifiable parental consent and prohibiting behavioural profiling.

How often should ROPA be updated? + ROPA should be treated as a living document with at minimum a quarterly human review cycle. Beyond scheduled reviews, it must be updated immediately whenever you onboard a new vendor or data processor, launch a new product feature that collects personal data, migrate systems or change cloud providers, revise retention policies, or receive a data principal rights request that reveals a previously undocumented processing activity. Consiva's automated ROPA refreshes continuously as its scanner detects changes in connected systems, eliminating reliance on manual review cycles as the sole update mechanism.

Can a spreadsheet-based ROPA satisfy DPDP audit requirements? + Technically a spreadsheet can contain the right information, but it carries significant practical risk under audit. Spreadsheets are static, manually maintained, and prone to version drift across departments. A stale spreadsheet with outdated vendor lists or missing data flows is arguably worse than no record at all — it demonstrates that the organisation documented obligations it then failed to track. Regulators conducting investigations are likely to probe for evidence that ROPA accurately reflects actual processing. Automated tools like Consiva link ROPA directly to live data sources, making accuracy independently verifiable rather than a matter of assertion.

What penalties apply if ROPA is inadequate under DPDP

2023? + The Digital Personal Data Protection Act 2023 prescribes financial penalties of up to ₹250 crore for significant data fiduciaries that fail to observe their obligations under Section 10, which includes maintaining accurate records. Section 33 grants the Data Protection Board power to impose penalties after a due inquiry process. Inadequate ROPA can also be cited as evidence of broader systemic non-compliance, compounding penalties that arise from separate violations (such as inadequate security measures or failure to fulfil data principal rights) discovered during the same inquiry. Does Consiva integrate with existing HR and CRM systems to populate ROPA automatically? + Yes. Consiva's data discovery engine connects to cloud databases (MySQL, PostgreSQL, MongoDB), SaaS platforms (Salesforce, HubSpot, Workday, SAP), and data warehouses (BigQuery, Snowflake, Redshift). It classifies personal data fields automatically using pattern recognition and machine learning, maps them to the appropriate departments and processing purposes, and populates the corresponding ROPA entries without requiring manual data entry or departmental interviews. All integrations use read-only OAuth 2.0 or API-key-based access — Consiva has no write permissions to your source systems at any point.

Related Articles

- Continue building your DPDP compliance knowledge
- Data Discovery How Data Discovery Enables DPDP Compliance: A Complete Guide 8 min read · DPDP Compliance
- E-Commerce DPDP Compliance Checklist for E-Commerce Businesses in India 11 min read · DPDP Compliance
- AI & Automation AI-Powered DPDP Compliance Automation: What Is Possible in 2026 7 min read · DPDP Compliance

Stay Ahead of DPDP Changes Get practical compliance insights, regulatory updates, and DPDP guidance delivered to your inbox — no fluff, twice a month. I agree to receive DPDP compliance updates and consent to Consiva processing my email for this purpose. [Privacy Policy](#) · [Subscribe](#)

India's DPDP compliance platform and consent management software — built natively for DPDP 2023, CERT-In, and global privacy frameworks. DPDP 2023 CERT-In GDPR Made in India  ISO 9001 Certified ISO 27001 Certified NASSCOM Member DSCI · DSCI/AM/2026/089 DPIIT Recognised Privacy contact (Rule 9): Saurabh K, Privacy Officer & Grievance Officer saurabhk@swaransoft.com

DPDP Knowledge DPDP Act 2023 DPDP Rules 2025 Data Fiduciary Obligations Data Principal Rights & Duties Retention & Erasure Penalties & Enforcement Compliance Blog Privacy Blueprint Industries SaaS & IT D2C & E-commerce BFSI Healthcare EdTech Startups Digital Marketing Agencies Trust & Legal Privacy Policy Terms of Service Cookie Policy Acceptable Use Policy Support Policy Privacy Rights & Grievance Refund & Cancellation Disclaimers & AI Notice Contact & Routing Company About Us Pricing Blog FAQ Contact Sitemap Login → Ask AI About Consiva Get an instant AI-generated overview Open your favorite AI assistant with a ready-made prompt about Consiva ChatGPT Perplexity Claude Google AI Grok © Consiva.ai · A product of Swaran Soft Support Solutions Private Limited CIN: U72200DL2005PTC136405 · GSTIN: 06AAJCS7515G1Z9 Tower A, Unit No. 2, 2nd Floor, The Cityscape, Sector-66, Golf Course Extension Road, Gurugram, Haryana – 122102, India support@consiva.ai · +91 9220313650 · ISO 9001:2015 & ISO/IEC 27001:2022 certified management systems within the scope of providing software development services.

67. How AI Is Transforming DPDP Compliance Automation for Indian Businesses | Consiva.ai

Source URL: <https://consiva.ai/blog/ai-powered-dpdp-compliance-automation>

How AI Is Transforming DPDP Compliance Automation for Indian Businesses | Consiva.ai ↑ ISO 9001 Certified · ISO 27001 Certified · NASSCOM Member · DSCI Member · DSCI/AM/2026/089 · DPIIT Recognised · Download White Paper Home Platform Platform Overview See the whole operating model — every module, one dashboard Consent & Notice Consent Management Platform Purpose-specific consent with signed, exportable records Cookie Consent Management Scans every cookie and tracker, including ones you didn't add DPDP and GDPR Consent Already run a GDPR CMP? What changes for DPDP Rights & Grievance Data Principal Rights Management Access, correction, erasure, grievance and nomination DSAR Management Software DSAR vs Data Principal request, explained Discovery, Mapping & Records Data Discovery Software Find personal data at rest, column by column Data Mapping Software Purpose-mapped data inventory from discovery findings ROPA Software A Records of Processing Activities register with source attribution Breach & Incident Data Breach Management CERT-In 6-hour and DPDP Rule 7 clocks, tracked independently Governance Processor & DPA Register Vendor DPA status, risk tiers and expiry alerts DPDP Knowledge DPDP Act 2023 Scope, definitions & key provisions of the law DPDP Rules 2025 Commencement dates & Rule-by-Rule breakdown Data Fiduciary Obligations Notice, consent & lawful processing under §§4–10 Data Principal Rights & Duties Your 4 rights & 5 duties as a data subject Retention & Erasure Rule 8: when to hold data and when to delete it Penalties & Enforcement Full penalty schedule — up to ₹250 Cr per violation FAQ Common questions about DPDP and Consiva Industry SaaS & IT Dual Fiduciary & Processor roles, offshore transfers D2C & E-commerce 2 Cr threshold, purchase consent & 3-year clock BFSI RBI & PMLA retention, defaulter data exemption Healthcare Fourth Schedule carve-out & patient data handling EdTech Rule 10 parental consent & child data protection Startups §17(3) exemptions & lean compliance playbook Digital Marketing Agencies Tag stack liability, Processor vs Fiduciary clarity Blog Pricing Contact Login → Dark Home > Blog > How AI Is Transforming DPDP Compliance Automation Technology 10 min read How AI-Powered Privacy Automation Is Transforming DPDP Compliance From reactive checklists to proactive intelligent systems — discover how machine learning, NLP, and anomaly detection are reshaping how Indian businesses meet their obligations under the Digital Personal Data Protection Act. C Consiva.ai Editorial Team 1 April 2026 2,200 words On This Page Reactive to Proactive AI Consent Collection DSR Processing with NLP Automated PII Detection AI-Assisted ROPA Real-Time Breach Detection Regulatory Monitoring Risks & Limitations Consiva's Responsible AI 2026–2027 Outlook FAQ From Reactive Checklists to Proactive Intelligence India's Digital Personal Data Protection (DPDP) Act 2023, along with the DPDP Rules that MeitY has been gradually rolling out in 2025 and 2026, has completely flipped the script on privacy compliance. What used to be a once-a-year audit exercise has now turned into a day-to-day, real-time obligation. You've got to get consent from

individuals right at the start of processing — can't start processing someone's data without it — you've got to get through Data Subject Requests (DSRs) within pretty tight timeframes and, in the unlikely event of a breach, report it to the Data Protection Board ASAP. To be honest, the volume of personal data a mid-sized Indian company has on its books is just too high for manual processes to keep up with — which is why more and more companies are starting to turn to AI to automate some of the more mundane, repetitive stuff (the bits that just involve spotting patterns over and over, for example) — but let's be clear, AI can't replace human judgement when it comes to tricky legal decisions.

Traditional vs. AI-Driven Compliance — contrasting legacy compliance methods with AI-driven equivalents across six task areas:

Compliance Task	Traditional Approach	AI-Driven Approach
Consent collection	Static banner, single language, manual log	Context-aware banner, auto-translated, cryptographically logged
DSR handling	Manual email triage, ~5-7 day average	NLP classification, auto-routing, drafted replies within hours
PII discovery	Manual spreadsheet interviews, quickly outdated	Continuous ML scanning of databases and file stores
ROPA maintenance	Annual workshop, Word doc, error-prone	LLM-assisted draft from discovered assets, human-approved, version-controlled
Breach detection	SIEM alerts, high false-positive rate, next-day review	Anomaly detection on access logs, real-time alerting, auto severity scoring
Regulatory updates	Counsel monitors gazette, sporadic briefings	Automated gazette parsing mapped instantly to obligation changes

AI-Driven Consent Collection

Consent under DPDP must be specific, informed, and freely given for each purpose, and easy to withdraw — something static cookie banners struggle to satisfy. AI-based consent tools address this through:

- Dynamic Banners That Ask the Right Questions at the Right Time**
Consent requests that make sense because they're based on what's actually going on on the page (like when someone is browsing a listing versus going through the checkout process) both make the company look more on the up and up and are more likely to be accepted by users.
- Preference Inference**
On-device models predict whether a returning visitor will re-consent to the same purposes, without sending personal data off the device.
- Multi-Language Support**
Domain-tuned translation models generate consent notices in Indian scheduled languages, with human review before publication — likely to become a formal requirement once MeitY finalizes notice-format rules.

Key Takeaway

The net effect of all this is that you should end up with a granular, auditable record of consent that can pass scrutiny from the Data Protection Board — no questions asked.

Intelligent DSR Processing with NLP

DPDP grants four core rights (access, correction, erasure, nomination of a representative), each generating its own request type and legal timeline. At scale, manual DSR queues get overwhelmed.

Classification and Routing

The way our transformer models know just what to do with free-text requests is nothing short of amazing — especially when it comes to Indian English dialects. They can categorise, route, and even pull out identity signals with an accuracy rate that's 94%+ in real-world tests.

Identity Verification

When checking if someone's identity matches what we already have on file, it's all about that confidence score — if it's low, we ask follow-up questions that are really targeted to get to the bottom of the issue.

Response Drafting

It takes an LLM to draft responses that are based on actual data from connected systems, not just someone's hunch — that way the people

doing the compliance checks can get through the work in a fraction of the time, down from hours to just minutes. Automated PII Detection in Databases You'll be wasting your time trying to protect personal data if you don't even know what PII is lurking out there in your databases — and manual searches just aren't going to cut it anymore. Structured scanning: column-level profiling plus regex for Aadhaar, PAN, Indian mobile numbers, IFSC and passport formats, plus statistical analysis to catch obfuscated identifier columns. Unstructured NER — it's a game changer: our transformer-based Named Entity Recognition tech can scan through all the unstructured bits like emails, tickets and chat logs and figure out what's genuinely PII and what's just wacky-sounding text. Sensitivity scoring: we're talking a multi-label classifier which tags data as standard or sensitive (health, financial or biometric data, religion) or kids' data — and that then tells you what level of protection you need to throw at it. Related capabilities: continuous re-scanning on schema changes, graph-based data-flow mapping for ROPA/DPIA documentation, and composite risk scoring per asset.

- 🔍 **Structured PII Scanning** Column profiling with regex patterns for Aadhaar, PAN, mobile, IFSC, and passport formats across SQL, NoSQL, and cloud data warehouses — continuous and non-invasive.
- 🧠 **NER on Unstructured Text** Fine-tuned BERT models identify PII in chat logs, support tickets, PDFs, and emails — understanding linguistic context rather than matching against fixed patterns.
- 🔑 **Sensitivity Classification** Multi-label classifiers assign sensitivity tiers aligned to DPDP Act definitions, automatically triggering the appropriate encryption, access control, and retention policies.
- ⚡ **Continuous Re-Scanning** Incremental scan jobs run on data-change events — new tables, new columns, schema migrations — ensuring the PII inventory stays accurate as infrastructure evolves.
- 🗺️ **Data Flow Mapping** Graph models trace how PII moves between microservices, third-party APIs, and storage systems, producing the data-flow diagrams required for ROPA and DPIA documentation.
- 📊 **Risk Scoring** Each discovered PII asset receives a composite risk score based on sensitivity tier, data volume, access control maturity, and retention coverage — prioritising remediation effort where it matters most.

AI-Assisted ROPA Generation A Record of Processing Activities (ROPA) breaks down every single processing event and maps it to the purpose, the legal angle, the kind of data you're dealing with, how long you need to keep it for, and which third parties are in the frame. Manual ROPA creation is a recipe for disaster — it takes weeks and is already outdated by the time you're finished. The AI-assisted workflow described here shaves weeks off that process and has five stages to it: Discovery input from the PII scanning layer (what data, where, how much). Contract/notice analysis — an LLM reads DPAs and privacy notices, citing source and page for each extracted claim. Field population — distinguishing confirmed, inferred, and missing information. Human review and approval, with full version control of changes. Continuous updates — new assets or vendor contracts automatically flag existing ROPA entries for review.

Start Free on Consiva.ai — No Credit Card Required Automate your DPDP consent management, DSR processing, PII discovery, and ROPA generation in under 30 minutes. Join hundreds of Indian businesses already building their compliance infrastructure on Consiva. Get Started Free Real-Time Breach Detection with Anomaly Detection Draft Rules say you have to report within 72 hours (just like GDPR's Article 33). But rule-based SIEM tools are just too bad at

it — they're churning out false alarms all the time. What you need is an Anomaly Detection tool — one that learns what normal behaviour looks like and flags up any big changes. How the Anomaly Detection Pipeline Works An Isolation Forest model scores individual access events for anomalousness in near real time. An LSTM autoencoder flags time-series access patterns (e.g., gradual export ramp-ups) that don't fit learned normal sequences. Example trigger signals include bulk queries outside normal hours or from unusual locations, an endpoint suddenly serving batch exports instead of single lookups, egress to unfamiliar external IPs, failed-login-then-success patterns consistent with credential stuffing, and services consuming more PII than their stated purpose requires. When a composite score crosses a threshold, the system opens an incident record, preserves evidence, assigns a preliminary severity score, and alerts the DPO — often hours ahead of manual detection. Production deployments reportedly cut false positives by 40-60% versus threshold-based SIEM.

AI for Regulatory Change Monitoring

Because DPDP's operational details are scattered across rules that MeitY is still publishing (with more to come in 2026-2027 on issues like consent manager licensing, kids' data, and Board procedure), keeping up with it all can be a real pain to stay on top of manually. AI can help though by crawling government sources, using an NLP classifier to pick out the bits that matter and then feeding those into a Large Language Model (LLM) to figure out exactly what needs to change — then handing the compliance officer a tidy little summary of what's new so they don't have to wade through reams of paperwork.

Risks and Limitations of AI in Privacy Compliance

AI tools need to be kept in check, rather than just blindly trusted. Four key areas are where the risks come in.

Hallucination Risk

Large Language Models can have a knack for producing confidently-asserted but completely made-up compliance info (like a fake retention period). To avoid this you need to make sure your LLMs are grounded in real verified sources, use structured output formats, and have a human double-check any regulator-facing output.

Bias in Consent Preference Models

Models trained on historical click data can inherit manipulative-UX biases, producing consent flows that under-inform some user groups — contrary to DPDP's informed-consent requirement.

Explainability Requirements

If an automated decision affects a Data Principal (e.g., delaying an erasure request as "potentially fraudulent"), the organisation must be able to explain it in plain language — favouring model designs whose outputs can be translated into human-readable rationale.

The Data Minimisation Paradox

Training better compliance models needs data, but DPDP requires collecting only the minimum necessary for a stated purpose — so training data must be synthetic, separately lawful, or within originally disclosed scope.

Where Consiva Stands Today

Notably, we want to draw a clear line between industry-wide direction and what Consiva itself currently ships. We describe our own automation as deliberately rule-based rather than model-based: Data Discovery and cookie/tracker categorisation rely on column-name heuristics and pattern/regex matching (not a trained NER or LLM classifier), chosen so every flagged finding traces back to an explicit rule rather than opaque model weights. We don't currently offer some pretty useful features like real-time anomaly-detection, draft ROPA entries written by an LLM, or NLP-based regulatory monitoring — those are more a case of following industry trends than something our AI can do right now.

But when we do use automated classification or suggestions, the output still needs to be reviewed by a human, in line with our publicly published Disclaimers & AI Notice . Any new AI features that do get added in the future will be subject to the same rules and guidelines as the ones we're using now — so no blind trust, and any changes will be clearly audited and traceable.

The Future of AI + DPDP Compliance: 2026–2027 We think the regulatory landscape is going to get a lot more demanding in the next couple of years, as MeitY ties up loose ends on the Significant Data Fiduciary rules (which will probably mean mandatory DPIAs, algorithmic audits and data-localisation requirements for sensitive data). On top of that the Data Protection Board is likely to start getting a lot more serious about enforcing the rules, possibly even issuing some pretty big fines in this timeframe.

Four trends will start to emerge in this space:

- Agentic compliance workflows:** we're talking multi-agent systems that can handle end-to-end tasks (say detect an issue → update ROPA → assess the risk → draft a notice amendment) without having to do manual legwork between tools.
- Federated PII scanning:** rather than having the analysis all centred on a single platform, this is all about doing it on-site in the data owner's own environment — driven by a desire to keep data sovereignty and make cross-border transfers easier.
- Model improvement that doesn't compromise your data:** we're talking about things like federated learning plus differential privacy to get improvements done on organisational data without that data ever leaving the organisation.
- Board-level compliance insights:** turning technical metrics (like consent rates, response times, PII risk scores, etc.) into something that makes sense for the board in terms of risk and financial impact.

The organisations that will navigate this landscape most effectively are those investing in AI-powered compliance infrastructure today — while there is still time to calibrate systems, train teams, and mature processes before enforcement intensity increases.

Consiva's pricing is designed to make world-class compliance automation accessible at every stage of growth, from early-stage startups to enterprise-scale Significant Data Fiduciaries. If you are unsure where to start, our compliance readiness assessment identifies your highest-priority gaps in under 15 minutes — get in touch with the team today .

Ready to Automate Your DPDP Compliance? Consiva handles consent management, DSR processing, PII discovery, ROPA generation, and breach monitoring — in one platform built for Indian businesses.

Start Free Trial View Pricing Frequently Asked Questions

Can AI fully automate DPDP compliance? + No — it accelerates routine tasks, but legal accountability sits with the Data Fiduciary and high-stakes decisions need human judgement.

How does NLP help DSR processing? + It classifies request type, extracts identity signals, routes to the right team, and drafts a response from connected-system data, cutting handling time from days to hours.

What ML techniques detect PII? + NER models tuned for Indian formats, regex for structured identifiers (Aadhaar, PAN, mobile, IFSC), transformer classifiers for unstructured text, and statistical column profiling.

How does AI spot breaches in real time? + Isolation Forest and LSTM autoencoders score events and time-series patterns for anomalies, sending an alert when a composite score crosses a threshold.

What is hallucination risk here, and how do you avoid it? + Hallucination risk is when a large language model starts making up plausible-but-wrong compliance facts. To manage it, ground the LLM in verified

sources, score its confidence, format the output so the source is traceable, and have a human double-check any regulator-facing output. Does AI use create explainability obligations? + Yes — if an automated decision affects a Data Principal, the organisation must be able to explain it in plain language on request. How does AI help maintain a ROPA? + ML-based discovery enumerates data assets, then an LLM maps them to ROPA fields using retrieval-augmented generation over contracts and notices, with compliance teams reviewing and approving the draft. Related Articles Continue reading about DPDP compliance Compliance How to Automate Your ROPA for DPDP Compliance 8 min read · April 2026 Technology Data Discovery for DPDP Compliance: A Practical Guide 7 min read · May 2026 SaaS DPDP Compliance for SaaS Companies: What You Must Do Now 9 min read · May 2026 Stay Ahead of DPDP Changes Get the latest DPDP rules, compliance guides, and Consiva product updates delivered to your inbox. No spam — unsubscribe any time. I agree to receive DPDP compliance updates and consent to Consiva processing my email for this purpose. Privacy Policy . Subscribe India's DPDP compliance platform and consent management software — built natively for DPDP 2023, CERT-In, and global privacy frameworks. DPDP 2023 CERT-In GDPR Made in India  ISO 9001 Certified ISO 27001 Certified NASSCOM Member DSCI · DSCI/AM/2026/089 DPIIT Recognised Privacy contact (Rule 9): Saurabh K, Privacy Officer & Grievance Officer saurabhk@swaransoft.com DPDP Knowledge DPDP Act 2023 DPDP Rules 2025 Data Fiduciary Obligations Data Principal Rights & Duties Retention & Erasure Penalties & Enforcement Compliance Blog Privacy Blueprint Industries SaaS & IT D2C & E-commerce BFSI Healthcare EdTech Startups Digital Marketing Agencies Trust & Legal Privacy Policy Terms of Service Cookie Policy Acceptable Use Policy Support Policy Privacy Rights & Grievance Refund & Cancellation Disclaimers & AI Notice Contact & Routing Company About Us Pricing Blog FAQ Contact Sitemap Login → Ask AI About Consiva Get an instant AI-generated overview Open your favorite AI assistant with a ready-made prompt about Consiva ChatGPT Perplexity Claude Google AI Grok © Consiva.ai · A product of Swaran Soft Support Solutions Private Limited CIN: U72200DL2005PTC136405 · GSTIN: 06AAJCS7515G1Z9 Tower A, Unit No. 2, 2nd Floor, The Cityscape, Sector-66, Golf Course Extension Road, Gurugram, Haryana – 122102, India support@consiva.ai · +91 9220313650 · ISO 9001:2015 & ISO/IEC 27001:2022 certified management systems within the scope of providing software development services.